



Πανεπιστήμιο Πειραιώς

Τμήμα Ψηφιακών Συστημάτων

Επίπεδο: Μεταπτυχιακό Πρόγραμμα Σπουδών

**«ScamAI - Σύστημα Ανίχνευσης Απάτης και Αυτοματοποιημένης Απόκρισης
(Scambaiting) με Τεχνητή Νοημοσύνη»**

Μάθημα	Προχωρημένα Θέματα Κυβερνοασφάλειας και Τεχνητής Νοημοσύνης
Εργασία	MSc Semester Project 1
Ομάδα	Βασιλειάδου Χρυσούλα (MTE25002), Βιτιόν Αντριάνα (MTE25006), Καλαϊτζίδης Ιωάννης (MTE25012), Καπνιά Δήμητρα (MTE25017), Μπούρας Ευάγγελος (MTE25036), Σπίνουλα Ιωάννα (MTE25044)

Πειραιάς

17/7/2026

Περίληψη

Η ηλεκτρονική απάτη μέσω email παραμένει από τις πιο επίμονες και οικονομικά επιζήμιες μορφές κυβερνοεγκλήματος, με τις απώλειες να μετρώνται σε δεκάδες δισεκατομμύρια δολάρια ετησίως (μόνο στις ΗΠΑ, το FBI IC3 κατέγραψε απώλειες 16,6 δις. δολαρίων το 2024) [47]. Η παρούσα εργασία σχεδιάζει, υλοποιεί και αξιολογεί το ScamAI, ένα σύστημα δύο σταδίων που συνδυάζει (α) την παθητική ανίχνευση scam/spam emails με μεθόδους Μηχανικής Μάθησης και (β) την ενεργητική απόκριση προς τους απατεώνες με Παραγωγική Τεχνητή Νοημοσύνη, υλοποιώντας τη λογική του scambaiting: την εσκεμμένη σπατάλη του χρόνου του απατεώνα ώστε να εκτρέπεται από πραγματικά θύματα.

Ο ταξινομητής εκπαιδεύτηκε σε ενοποιημένο σύνολο 13.919 emails από τρεις ανεξάρτητες πηγές (συνθετικά δεδομένα, Enron Fraud Dataset, SpamAssassin) και συγκρίθηκε ένα baseline μοντέλο Multinomial Naive Bayes έναντι ενός Random Forest. Το τελικό μοντέλο (Random Forest με `class_weight="balanced"`) πέτυχε ROC-AUC 0,815 και recall 0,65 στην κλάση απάτης, με σχεδιαστική προτεραιότητα στην ευαισθησία - κρίσιμη επιλογή για ένα αμυντικό φίλτρο. Ο responder υλοποιεί διακριτές «περσόνες» ανά τύπο απάτης, υποστηρίζει multi-turn συνομιλία, αφαιρεί (abstraction) μεταξύ πολλαπλών παρόχων LLM και ενσωματώνει ρητό έλεγχο ασφαλείας εξόδου (safety guardrail) καθώς και άμυνα σε επιθέσεις prompt injection.

Πέρα από την τεχνική υλοποίηση, η εργασία αναπτύσσει εκτενή νομική και κανονιστική ανάλυση (GDPR, Πράξη για την Τεχνητή Νοημοσύνη - ιδίως το Άρθρο 50 περί διαφάνειας, NIS2, Οδηγία 2013/40/ΕΕ για το κυβερνοέγκλημα, ελληνικός Ν. 4624/2019, Ν. 3471/2006 και Άρθρο 9Α του Συντάγματος) καθώς και ηθική αποτίμηση του «παραδόξου του δόλου» που ενυπάρχει στο αυτοματοποιημένο scambaiting. Συμπερασματικά, καταδεικνύεται ότι η ενεργητική άμυνα απέναντι στην απάτη είναι τεχνικά εφικτή, αλλά αξεδιάλυτα συνδεδεμένη με νομικές και ηθικές δεσμεύσεις που καθιστούν αναγκαία τη λειτουργία εντός θεσμικού πλαισίου και υπό ανθρώπινη εποπτεία.

Λέξεις-κλειδιά: ανίχνευση απάτης, spam filtering, scambaiting, Παραγωγική TN, Μηχανική Μάθηση, Random Forest, GDPR, AI Act, Υπεύθυνη TN, prompt injection.

Abstract

Email fraud remains among the most persistent and costly forms of cybercrime, with reported losses in the tens of billions of dollars annually (in the US alone, the FBI IC3 recorded \$16.6 billion in 2024) [47]. This work designs, implements and evaluates ScamAI, a two-stage system that combines the *passive* detection of scam/spam emails via Machine Learning with the *active* engagement of scammers via Generative AI, realising the logic of *scambaiting*: deliberately wasting a scammer’s time so as to divert them from real victims. A classifier was trained on a unified corpus of 13,919 emails from three independent sources, comparing a Multinomial Naive Bayes baseline against a Random Forest. The final model (Random Forest with balanced class weights) achieved a ROC-AUC of 0.815 and recall of 0.65 on the fraud class, deliberately prioritising sensitivity as befits a defensive filter. The responder implements distinct per-scam-type personas, supports multi-turn conversation, abstracts over multiple LLM providers, and enforces an explicit output safety guardrail and defences against *prompt injection*. Beyond the technical implementation, the work develops an extensive legal and regulatory analysis (GDPR, the AI Act - notably its Article 50 transparency obligation, NIS2, the cybercrime Directive 2013/40/EU, and Greek Law 4624/2019) together with an ethical assessment of the “deception paradox” inherent in automated scambaiting. It concludes that active defence against fraud is technically feasible but inextricably bound to legal and ethical constraints that mandate an institutional framework and human oversight.

Keywords: fraud detection, spam filtering, scambaiting, Generative AI, Machine Learning, Random Forest, GDPR, AI Act, Responsible AI, prompt injection.

Περιεχόμενα

1. Εισαγωγή	1
1.1. Πλαίσιο και κίνητρο.....	1
1.2. Το πρόβλημα.....	1
1.3. Από την ανίχνευση στην ενεργητική εμπλοκή	2
1.4. Ερευνητικά ερωτήματα.....	2
1.5. Στόχοι και συνεισφορά	2
1.6. Δομή του κειμένου.....	3
2. Θεωρητικό Υπόβαθρο.....	3
2.1. Ηλεκτρονική απάτη: ταξινομία.....	3
2.2. Κοινωνική μηχανική και αρχές πειθούς	4
2.3. Μηχανική Μάθηση για ταξινόμηση κειμένου	5
2.3.1. Naïve Bayes	5
2.3.2. Δέντρα απόφασης και Random Forest.....	6
2.4. Ανισορροπία κλάσεων	7
2.5. Μετρικές αξιολόγησης.....	7
2.6. Μεγάλα Γλωσσικά Μοντέλα και prompting	8
3. Βιβλιογραφική Επισκόπηση	8
3.1. Εξέλιξη του φιλτραρίσματος spam	8
3.2. Ανίχνευση phishing	9

3.3. Απάτη προκαταβολικής αμοιβής («419»)	10
3.4. Χειροκίνητο scambaiting και ηθική	10
3.5. Αυτοματοποιημένο scambaiting με Παραγωγική ΤΝ	11
3.6. Ασφάλεια LLM και prompt injection	13
3.7. Θέση της παρούσας εργασίας	13
4. Δεδομένα και Προεπεξεργασία	14
4.1. Πηγές δεδομένων	14
4.2. Συγχώνευση και απαλοιφή διπλοτύπων	15
4.3. Καθαρισμός κειμένου	15
4.4. Μηχανική χαρακτηριστικών (feature engineering)	15
4.5. Στατιστικά και διαχωριστική ισχύς	16
4.6. Ανισορροπία κλάσεων	17
5. Σχεδιασμός και Μεθοδολογία Συστήματος	17
5.1. Αρχιτεκτονική	17
5.2. Μοντέλο απειλής	17
5.3. Ταξινομητής	18
5.4. Responder	18
5.4.1. Ταυτοποίηση τύπου απάτης	18
5.4.2. Περσόνες	19
5.4.3. Σχεδίαση prompt	19
5.4.4. Αφαίρεση παρόχων (provider abstraction)	20

5.4.5. Multi-turn συνοχή	20
5.5. Έλεγχος ασφαλείας εξόδου.....	20
5.6. Άμυνα σε prompt injection	21
6. Υλοποίηση	21
6.1. Τεχνολογικό stack.....	22
6.2. Δομή modules	22
6.3. Ο mock provider ως εργαλείο ποιότητας.....	22
6.4. Διαδραστικό demo (Streamlit).....	23
6.5. Στρατηγική δοκιμών	23
7. Πειραματικά Αποτελέσματα.....	23
7.1. Πειραματική διάταξη	24
7.2. Συγκριτική αξιολόγηση μοντέλων	24
7.3. Πίνακας σύγκυσης (Random Forest)	25
7.4. Σημαντικότητα χαρακτηριστικών	26
7.5. Ανάλυση σφάλματος και κατώφλι απόφασης	27
7.6. Ποιοτική αξιολόγηση responder	28
7.7. Ανάλυση πολυγυρικής συνομιλίας	30
7.8. Αξιολόγηση ελέγχου ασφαλείας.....	30
8. Νομικό και Κανονιστικό Πλαίσιο	30
8.1. Χαρτογράφηση εφαρμοστέου δικαίου.....	31
8.2. Γενικός Κανονισμός Προστασίας Δεδομένων (GDPR)	31

8.3. Πράξη για την Τεχνητή Νοημοσύνη (AI Act) — Άρθρο 50	34
8.4. NIS2 και threat intelligence	35
8.5. Ποινικό δίκαιο και κυβερνοέγκλημα	35
8.6. Ελληνικό πλαίσιο	36
8.7. Ενδεικτική άσκηση DPIA	36
8.8. Συμμόρφωση εκ σχεδιασμού (compliance by design).....	37
8.9. Ευθύνη και δικαιοδοσία	37
9. Ηθική Ανάλυση.....	38
9.1. Το παράδοξο του δόλου.....	38
9.2. Ωφελιμιστική, δεοντολογική και αρετολογική οπτική	38
9.3. Ευάλωτοι πληθυσμοί	39
9.4. Βλάβη σε τρίτους και διπλή χρήση (dual-use)	40
9.5. Αντιστοίχιση με αρχές Υπεύθυνης ΤΝ	40
10. Μελλοντική Εργασία	40
11. Συμπεράσματα	41
11.1. Απαντήσεις στα ερευνητικά ερωτήματα.....	41
11.2. Συνεισφορά	42
11.3. Περιορισμοί	42
11.4. Καταληκτικές παρατηρήσεις	43
12. Βιβλιογραφία	43
12.1. Επιστημονική βιβλιογραφία	43

12.2. Νομικά μέσα	46
12.3. Πρόσθετες αναφορές (ενεργητική άμυνα & απάτη).....	47
13. Παραρτήματα.....	48
13.1. Παράρτημα Α — Πλήρες transcript multi-turn (mock provider)	48
13.2. Παράρτημα Β — Ορισμοί χαρακτηριστικών	48
13.3. Παράρτημα Γ — Γλωσσάρι.....	48
13.4. Παράρτημα Δ — Κατανομή ρόλων ομάδας.....	49
13.5. Παράρτημα Ε — Επιλεγμένα αποσπάσματα κώδικα	49
13.5.1. Ε.1 Εξαγωγή χαρακτηριστικών (preprocessing/preprocess.py)	49
13.5.2. Ε.2 Μοτίβα εντοπισμού ΡΠ (responder/responder.py)	51
13.5.3. Ε.3 Έλεγχος ασφαλείας εξόδου (responder/responder.py).....	51

1. Εισαγωγή

1.1. Πλαίσιο και κίνητρο

Η μαζική υιοθέτηση του ηλεκτρονικού ταχυδρομείου ως κύριου μέσου επικοινωνίας κατέστησε το email και το βασικό όχημα διάδοσης της ηλεκτρονικής απάτης. Σύμφωνα με στοιχεία της αμερικανικής Federal Trade Commission, οι αναφερόμενες απώλειες καταναλωτών από απάτες ξεπέρασαν τα 12,5 δισεκατομμύρια δολάρια το 2024, σημειώνοντας αύξηση περίπου 25% σε σχέση με το προηγούμενο έτος. Το μέγεθος αυτό, σε συνδυασμό με τη διαρκή προσαρμογή των επιτιθέμενων, δείχνει ότι παρά την ωριμότητα των αντι-spam φίλτρων η απειλή όχι μόνο δεν υποχωρεί αλλά εξελίσσεται ταχύτερα από την άμυνα.

Χαρακτηριστικό των περισσότερων απατών μέσω email είναι ότι βασίζονται λιγότερο σε τεχνική εκμετάλλευση ευπαθειών και περισσότερο στην κοινωνική μηχανική (social engineering): στη μεθοδική ψυχολογική χειραγώγηση του θύματος μέσω αρχών πειθούς όπως η αυθεντία, η σπανιότητα και το επείγον. Ο ανθρώπινος παράγοντας, και όχι το λογισμικό, αποτελεί τον πραγματικό στόχο.

1.2. Το πρόβλημα

Η κυρίαρχη προσέγγιση άμυνας παραμένει *παθητική*: ένα φίλτρο ταξινομεί ένα εισερχόμενο μήνυμα ως νόμιμο ή ανεπιθύμητο και, στη δεύτερη περίπτωση, το απορρίπτει. Παρότι αποτελεσματική στην προστασία του μεμονωμένου χρήστη, η προσέγγιση αυτή δεν επιβάλλει κανένα κόστος στον απατεώνα: το μήνυμα απλώς αγνοείται, ενώ ο επιτιθέμενος συνεχίζει ανενόχλητος να στοχεύει άλλα, λιγότερο προστατευμένα θύματα.

1.3. Από την ανίχνευση στην ενεργητική εμπλοκή

Τα τελευταία χρόνια αναδύεται μια συμπληρωματική, *ενεργητική* στρατηγική. Αντί απλώς να απορρίπτεται το κακόβουλο μήνυμα, ένα αυτοματοποιημένο σύστημα *απαντά* στον απατεώνα, προσποιούμενο ένα υποψήφιο θύμα, με στόχο να τον απασχολήσει, να σπαταλήσει τον χρόνο και τους πόρους του και -ιδανικά- να εξαγάγει αξιοποιήσιμες πληροφορίες απειλής (threat intelligence), όπως τραπεζικούς λογαριασμούς «μουλαριών» (mule accounts). Η προσέγγιση αυτή, γνωστή ως *scambaiting*, τοποθετείται στο ευρύτερο πεδίο της «ενεργητικής άμυνας» (active defense) [41], [42] και των «συνομιλιακών honeypots», και μετατοπίζει -μερικώς- το κόστος από το θύμα προς τον επιτιθέμενο.

1.4. Ερευνητικά ερωτήματα

Η εργασία διαρθρώνεται γύρω από τέσσερα ερωτήματα:

1. Μπορεί ένα *ερμηνεύσιμο*, ελαφρύ σύνολο χαρακτηριστικών να επιτύχει χρήσιμη ανίχνευση απάτης σε ρεαλιστικά, μη ισορροπημένα δεδομένα;
2. Πώς μπορεί ένα σύστημα Παραγωγικής ΤΝ να παράγει *πειστικές αλλά ασφαλείς* αποκρίσεις *scambaiting*;
3. Ποιοι κίνδυνοι ασφαλείας (π.χ. prompt injection) και ποια μέτρα άμυνας προκύπτουν από την ανάπτυξη ενός γλωσσικού πράκτορα σε εχθρικό περιβάλλον;
4. Ποιο νομικό και ηθικό πλαίσιο θα διείπε μια πραγματική ανάπτυξη ενός τέτοιου συστήματος;

1.5. Στόχοι και συνεισφορά

Στόχος είναι η ολοκλήρωση ενός διαφανούς, πλήρως προσομοιωμένου και offline-δυνατού συστήματος που καλύπτει όλη την αλυσίδα anti-scam: ανίχνευση → ταυτοποίηση τύπου απάτης → απόκριση → έλεγχος ασφαλείας. Η συνεισφορά είναι πρωτίστως διδακτική: το ScamAI δεν επιδιώκει state-of-the-art απόδοση, αλλά αποτελεί ένα πλήρες, αναπαραγώγιμο παράδειγμα ενσωμάτωσης Μηχανικής Μάθησης, Παραγωγικής ΤΝ και αρχών Υπεύθυνης ΤΝ, συνοδευόμενο από ενδελεχή ανάλυση του κανονιστικού και ηθικού του πλαισίου.

1.6. Δομή του κειμένου

Το Κεφάλαιο 2 παρουσιάζει το θεωρητικό υπόβαθρο. Το Κεφάλαιο 3 αναπτύσσει εκτενή βιβλιογραφική επισκόπηση. Το Κεφάλαιο 4 περιγράφει τα δεδομένα και την προεπεξεργασία. Τα Κεφάλαια 5 και 6 καλύπτουν τον σχεδιασμό/μεθοδολογία και την υλοποίηση. Το Κεφάλαιο 7 παρουσιάζει τα πειραματικά αποτελέσματα. Το Κεφάλαιο 8 αναπτύσσει το νομικό/κανονιστικό πλαίσιο και το Κεφάλαιο 9 την ηθική ανάλυση. Τα Κεφάλαια 10 και 11 περιλαμβάνουν τη μελλοντική εργασία και τα συμπεράσματα.

2. Θεωρητικό Υπόβαθρο

2.1. Ηλεκτρονική απάτη: ταξινόμια

Οι απάτες μέσω email δεν αποτελούν ομοιογενή κατηγορία. Στο ScamAI διακρίνονται πέντε βασικοί τύποι, καθένας με διαφορετικό «σενάριο» πειθούς:

- Απάτη προκαταβολικής αμοιβής («419»/Nigerian prince): υπόσχεται ένα τεράστιο ποσό (κληρονομιά, δέσμευση κεφαλαίων) έναντι μιας μικρής αρχικής πληρωμής για «τέλη» ή «δωροδοκίες». Εκμεταλλεύεται την απληστία και την αυθεντία (πλαστοί αξιωματούχοι, τραπεζίτες).

- Απάτη λαχείου/κλήρωσης (*lottery*): ενημερώνει το θύμα ότι «κέρδισε» έπαθλο σε κλήρωση στην οποία δεν συμμετείχε ποτέ, ζητώντας «τέλη απελευθέρωσης». Εκμεταλλεύεται τη σπανιότητα και το επείγον.
- Ρομαντική απάτη (*romance*): χτίζει μια ψεύτικη συναισθηματική σχέση σε βάθος χρόνου πριν ζητήσει χρήματα για «έκτακτη ανάγκη». Εκμεταλλεύεται τη μοναξιά, τη συμπάθεια και τη δέσμευση.
- Επενδυτική απάτη (*investment*): προσφέρει «εγγυημένες» υπερβολικές αποδόσεις, συχνά με κρυπτονομίσματα. Εκμεταλλεύεται την απληστία και τον φόβο απώλειας ευκαιρίας (FOMO).
- Phishing: μιμείται νόμιμο φορέα (τράπεζα, πάροχο) για να υποκλέψει διαπιστευτήρια μέσω πλαστού συνδέσμου. Εκμεταλλεύεται την αυθεντία και τον φόβο (π.χ. «ο λογαριασμός σας ανεστάλη»).

Παρά τις διαφορές, όλοι οι τύποι μοιράζονται κοινά γλωσσικά ίχνη: αίσθηση επείγοντος, υποσχέσεις χρημάτων και εκκλήσεις σε αυθεντία ή εμπιστοσύνη. Αυτά ακριβώς τα ίχνη αποτελούν τη βάση τόσο της ανίχνευσης (χαρακτηριστικά) όσο και της ταυτοποίησης τύπου (keyword scoring) στο ScamAI.

2.2. Κοινωνική μηχανική και αρχές πειθούς

Η θεωρητική βάση για την κατανόηση αυτών των «σεναρίων» προέρχεται από την ψυχολογία της πειθούς. Ο Cialdini [9] διατύπωσε τις κλασικές αρχές επιρροής: *αμοιβαιότητα* (η τάση ανταπόδοσης μιας χάρης), *δέσμευση και συνέπεια* (η τάση εμμονής σε προηγούμενες δεσμεύσεις), *κοινωνική απόδειξη* (μίμηση της συμπεριφοράς των άλλων), *αυθεντία* (υπακοή σε φαινομενικούς ειδικούς), *συμπάθεια* (ευκολότερη πειθώ από αρεστά πρόσωπα), *σπανιότητα* (αυξημένη αξία του δυσεύρετου) και -σε νεότερες εκδόσεις- *ενότητα* (κοινή ταυτότητα). Στις απάτες email, η αυθεντία εμφανίζεται ως πλαστός «τραπεζικός διευθυντής» ή «πρίγκιπας», η σπανιότητα ως «περιορισμένος χρόνος για να διεκδικήσετε το έπαθλο», και η αμοιβαιότητα ως η υπόσχεση τεράστιου ποσοστού έναντι μικρής «βοήθειας».

Παράλληλα, ο Gragg [10] περιέγραψε ψυχολογικούς «σκανδαλιστές» (triggers) ειδικά για επιθέσεις κοινωνικής μηχανικής, όπως η υπερφόρτωση πληροφορίας και η επιθυμία βοήθειας. Οι Stajano & Wilson [11], στο πλαίσιο της ασφάλειας συστημάτων, κωδικοποίησαν επτά αρχές που εκμεταλλεύονται συστηματικά οι απατεώνες - μεταξύ άλλων τις αρχές του χρόνου/επείγοντος, της απληστίας, της κοινωνικής συμμόρφωσης και της δέσμευσης. Οι Ferreira et al. [12] συνένωσαν τις τρεις αυτές ταξινομίες σε ενιαία λίστα και, αναλύοντας πραγματικά phishing emails, έδειξαν ότι κυριαρχούν κυρίως η αυθεντία και η έντονη συναισθηματική φόρτιση/αντιπερισπασμός.

Η κατανόηση αυτών των αρχών είναι κρίσιμη σε δύο επίπεδα. Για την *ανίχνευση*, τα γλωσσικά αποτυπώματα του επείγοντος (θαυμαστικά, κεφαλαία, λέξεις-κλειδιά όπως «urgent», «guaranteed») γίνονται διακριτικά χαρακτηριστικά - ακριβώς αυτά που εξάγει το ScamAI. Για τον *responder*, μια αξιόπιστη περσόνα πρέπει να «απαντά» στους ίδιους ψυχολογικούς μοχλούς που ο απατεώνας αναμένει από ένα υποψήφιο θύμα: να δείχνει π.χ. απληστία (ανταποκρινόμενη στην υπόσχεση κέρδους) ή σύγχυση (παρατείνοντας την αλληλεπίδραση).

2.3. Μηχανική Μάθηση για ταξινόμηση κειμένου

2.3.1. Naive Bayes

Ο Multinomial Naive Bayes είναι πιθανοτικός ταξινομητής που εφαρμόζει το θεώρημα του Bayes υπό την «αφελή» υπόθεση της υπό συνθήκη ανεξαρτησίας των χαρακτηριστικών. Για ένα διάνυσμα χαρακτηριστικών $x=(x_1,\dots,x_n)$ και κλάση c , η εκ των υστέρων πιθανότητα δίνεται από:

$$P(c|x)=\frac{P(c) \prod_{i=1}^n P(x_i|c)}{P(x)}$$

Η πρόβλεψη είναι η κλάση που μεγιστοποιεί τον αριθμητή (MAP estimate). Παρότι η υπόθεση ανεξαρτησίας σπανίως ισχύει στην πράξη (π.χ. το word_count και το unique_words

συσχετίζονται έντονα), ο ταξινομητής παραμένει εκπληκτικά ανθεκτικός και αποτέλεσε το θεμέλιο του φιλτραρίσματος spam [1], [2] λόγω απλότητας, ταχύτητας εκπαίδευσης και ερμηνευσιμότητας. Η πολωνυμική (multinomial) παραλλαγή απαιτεί μη αρνητικές τιμές εισόδου, εξ ου και η κανονικοποίηση με MinMaxScaler στην παρούσα εργασία, που απεικονίζει κάθε χαρακτηριστικό στο διάστημα [0,1]. Το βασικό μειονέκτημα, όπως θα φανεί στα αποτελέσματα, είναι η ευαισθησία του σε έντονα μη ισορροπημένες κατανομές, όπου τείνει να ευνοεί την πλειοψηφική κλάση.

2.3.2. Δέντρα απόφασης και Random Forest

Ένα δέντρο απόφασης διαχωρίζει επαναληπτικά τον χώρο των χαρακτηριστικών ώστε να μεγιστοποιεί την «καθαρότητα» των κόμβων. Ένα κοινό κριτήριο είναι η ακαθαρσία Gini, $G=1-\sum_k p_k^2$, όπου p_k η αναλογία της κλάσης k στον κόμβο· κάθε διαχωρισμός επιλέγεται ώστε να ελαχιστοποιεί τη σταθμισμένη ακαθαρσία των παιδιών. Τα μεμονωμένα δέντρα, ωστόσο, υπερπροσαρμόζονται εύκολα (υψηλή διακύμανση).

Ο Random Forest [5] αντιμετωπίζει το πρόβλημα με δύο μηχανισμούς τυχαιότητας: (i) *bootstrap aggregation* (bagging) - κάθε δέντρο εκπαιδεύεται σε τυχαίο δείγμα με επανάθεση· και (ii) *τυχαία υποσύνολα χαρακτηριστικών* σε κάθε διαχωρισμό, που αποσυσχετίζει τα δέντρα. Η τελική πρόβλεψη προκύπτει με «ψηφοφορία» (majority vote) ή μέσο όρο πιθανοτήτων. Το αποτέλεσμα είναι ένας ισχυρός, ανθεκτικός σε θόρυβο ταξινομητής χαμηλής διακύμανσης. Επιπλέον, ο Random Forest παρέχει *μέτρο σημαντικότητας χαρακτηριστικών* (mean decrease in impurity), το οποίο αξιοποιείται στην §7.5 για ερμηνευσιμότητα. Στην παρούσα εργασία χρησιμοποιούνται 200 δέντρα με μέγιστο βάθος 10 - αρκετά ώστε να συλλάβουν μη γραμμικές αλληλεπιδράσεις μεταξύ των χαρακτηριστικών, αλλά περιορισμένα ώστε να μην υπερπροσαρμοστούν στο μικρό ποσοστό των δειγμάτων απάτης. Η παράμετρος `class_weight="balanced"` σταθμίζει αντιστρόφως ανάλογα προς τη συχνότητα κάθε κλάσης, επιβάλλοντας βαρύτερη ποινή στα σφάλματα της μειοψηφικής κλάσης απάτης.

2.4. Ανισορροπία κλάσεων

Στο φιλτράρισμα email η κλάση της απάτης είναι εγγενώς μειοψηφική. Ένας ταξινομητής που βελτιστοποιεί την ακρίβεια (accuracy) τείνει να «καταρρέει» προβλέποντας πάντα την πλειοψηφική κλάση. Οι κύριες αντιμετωπίσεις είναι: (i) *over-sampling* της μειοψηφίας (π.χ. SMOTE [6], που παράγει συνθετικά δείγματα), (ii) *under-sampling* της πλειοψηφίας, και (iii) *στάθμιση κλάσεων* (class_weight), που επιβάλλει βαρύτερη ποινή στα σφάλματα της μειοψηφικής κλάσης - η προσέγγιση που υιοθετεί το ScamAI.

2.5. Μετρικές αξιολόγησης

Λόγω της ανισορροπίας, η *accuracy* είναι παραπλανητική: ένας ταξινομητής που προβλέπει πάντα «νόμιμο» πετυχαίνει 92,3% accuracy χωρίς να εντοπίσει καμία απάτη. Οι κατάλληλες μετρικές ορίζονται μέσω των μεγεθών του πίνακα σύγχυσης - αληθώς θετικά (TP), ψευδώς θετικά (FP), αληθώς αρνητικά (TN), ψευδώς αρνητικά (FN):

$$\text{Precision} = \frac{TP}{TP+FP}, \quad \text{Recall} = \frac{TP}{TP+FN}, \quad F_1 = 2 \cdot \frac{\text{Precision} \cdot \text{Recall}}{\text{Precision} + \text{Recall}}$$

Η Precision μετρά πόσες από τις σημάνσεις «απάτη» ήταν ορθές· το Recall πόσες από τις πραγματικές απάτες εντοπίστηκαν· το F1-score είναι ο αρμονικός τους μέσος. Το ROC-AUC (εμβαδόν κάτω από την καμπύλη True Positive Rate έναντι False Positive Rate) εκφράζει την ικανότητα διαχωρισμού ανεξαρτήτως κατωφλίου: τιμή 0,5 ισοδυναμεί με τυχαία πρόβλεψη, 1,0 με τέλει διαχωρισμό. Σε ένα αμυντικό σύστημα, το κόστος ενός ψευδώς αρνητικού (μια απάτη που ξεφεύγει) υπερβαίνει συνήθως το κόστος ενός ψευδώς θετικού (ένα νόμιμο email που περνά για επιπλέον έλεγχο)· επομένως, το recall προτεραιοποιείται έναντι της precision - σχεδιαστική επιλογή που καθορίζει και την ανάγνωση των αποτελεσμάτων στο κεφάλαιο 7.

2.6. Μεγάλα Γλωσσικά Μοντέλα και prompting

Τα Μεγάλα Γλωσσικά Μοντέλα (LLMs) είναι νευρωνικά δίκτυα αρχιτεκτονικής transformer, εκπαιδευμένα σε τεράστια σώματα κειμένου ώστε να προβλέπουν την επόμενη λεξική μονάδα (token) δεδομένου ενός context. Η συμπεριφορά τους σε μια εφαρμογή καθοδηγείται χωρίς επανεκπαίδευση, μέσω *prompting*. Κρίσιμα στοιχεία είναι: το system prompt (οδηγίες ρόλου και συμπεριφοράς που ορίζουν την «ταυτότητα» του βοηθού), τα μηνύματα χρήστη (user) που φέρουν το εξωτερικό περιεχόμενο, το conversation history (για συνοχή σε πολυγυρικές συνομιλίες) και υπερπαράμετροι όπως η *temperature* (που ρυθμίζει την τυχαιότητα/δημιουργικότητα της εξόδου). Το *few-shot prompting* (παροχή παραδειγμάτων μέσα στο prompt) βελτιώνει συχνά τη συνέπεια.

Δύο έννοιες είναι κεντρικές για την εργασία. Πρώτον, η περσόνα: μια συνεπής «ταυτότητα» που το μοντέλο υποδύεται σταθερά σε όλη τη συνομιλία, καθορισμένη στο system prompt. Δεύτερον, ο διαχωρισμός δεδομένων από εντολές: τα εξωτερικά, μη έμπιστα δεδομένα (εν προκειμένω το email του απατεώνα) δεν πρέπει να ερμηνεύονται ως εντολές προς το μοντέλο. Η αρχή αυτή είναι η βασική άμυνα απέναντι στο prompt injection (§3.6) και υλοποιείται στο ScamAI με την περιτύλιξη του εχθρικού κειμένου σε ρητά οριοθετημένα tags και τη σαφή οδηγία μη εκτέλεσης εντολών του (§5.5).

3. Βιβλιογραφική Επισκόπηση

3.1. Εξέλιξη του φιλτραρίσματος spam

Η ανίχνευση ανεπιθύμητης αλληλογραφίας εξελίχθηκε σε τρεις μεγάλες φάσεις. Η πρώτη, *βασισμένη σε κανόνες*, στηριζόταν σε στατικές λίστες αποκλεισμού (blocklists) διευθύνσεων και σε χειροποίητους κανόνες λέξεων-κλειδιών· ήταν εύκολα παρακάμψιμη από

μικρές παραλλαγές («n1agra») και απαιτούσε διαρκή χειροκίνητη συντήρηση. Η δεύτερη, *πιθανοτική/στατιστική*, εισήγαγε τη Μηχανική Μάθηση: το θεμελιώδες έργο των Sahami et al. [1] εφάρμοσε τον Μπεϊζιανό ταξινομητή σε junk email, και οι Androutsopoulos et al. [2] το αξιολόγησαν συστηματικά, εδραιώνοντας το παράδειγμα «bag-of-words» όπου κάθε μήνυμα αναπαρίσταται ως διάνυσμα συχνοτήτων λέξεων. Η προσέγγιση αυτή προσαρμόζεται αυτόματα και είναι δύσκολο να παρακαμφθεί συστηματικά.

Η τρίτη, *σύγχρονη* φάση αξιοποιεί βαθιά μάθηση και αναπαραστάσεις κειμένου υψηλής διάστασης. Οι επισκοπήσεις των Dada et al. [3] και Karim et al. [4] χαρτογραφούν το πλήρες φάσμα μεθόδων (SVM, δέντρα απόφασης, τυχαία δάση, νευρωνικά δίκτυα) και δύο επίμονα ανοικτά προβλήματα: το *concept drift* (η κατανομή του spam μεταβάλλεται καθώς οι επιτιθέμενοι προσαρμόζονται, υποβαθμίζοντας τα εκπαιδευμένα μοντέλα) και οι *αντιπαλικές επιθέσεις* (σκόπιμες τροποποιήσεις για διαφυγή από τον ταξινομητή). Οι πιο πρόσφατες προσεγγίσεις αξιοποιούν TF-IDF, word embeddings και αρχιτεκτονικές transformers [7], [8], επιτυγχάνοντας πολύ υψηλή ακρίβεια σε μεγάλα corpora - με κόστος όμως στην ερμηνευσιμότητα, στους υπολογιστικούς πόρους και στην ανάγκη μεγάλων συνόλων εκπαίδευσης. Το ScamAI τοποθετείται συνειδητά στη δεύτερη φάση, επιλέγοντας ένα διαφανές, ελαφρύ μοντέλο ως εκπαιδευτικό αντιστάθμισμα στην αδιαφάνεια των βαθιών δικτύων.

3.2. Ανίχνευση phishing

Το phishing αντιμετωπίζεται με τρεις οικογένειες χαρακτηριστικών: (i) *URL-based* (μήκος διεύθυνσης, εντροπία, χρήση IP αντί domain, ύποπτες κατασκευές, typosquatting)· (ii) *header-based* (αποτυχία ελέγχων SPF/DKIM/DMARC, ασυμφωνίες μεταξύ εμφανιζόμενου και πραγματικού αποστολέα)· και (iii) *content-based* (γλωσσικά σήματα επείγοντος, αιτήματα διαπιστευτηρίων, ασυμφωνίες μάρκας). Οι content-based προσεγγίσεις με TF-IDF και γραμμικά μοντέλα [3] παραμένουν ισχυρές και ερμηνεύσιμες, ενώ οι σύγχρονες αρχιτεκτονικές transformers [8] βελτιώνουν την απόδοση σε βάρος της διαφάνειας. Η παρούσα εργασία εντάσσεται στην content-based οικογένεια με σκόπιμα ελαφρύ σύνολο χαρακτηριστικών, θυσιάζοντας την πρόσβαση σε σήματα URL/header (που δεν υπάρχουν στο ενοποιημένο,

κειμενικό dataset) χάριν απλότητας και αναπαραγωγιμότητας. Αυτή η επιλογή θέτει και ένα φυσικό όριο απόδοσης: πολλά phishing emails είναι γλωσσικά «καθαρά» και διακρίνονται μόνο από τα τεχνικά τους μεταδεδομένα - στοιχείο που εξηγεί μέρος των false negatives (§7.6).

3.3. Απάτη προκαταβολικής αμοιβής («419»)

Οι απάτες «419» (από το σχετικό άρθρο του Νιγηριανού Ποινικού Κώδικα) μελετώνται εδώ και δεκαετίες. Οι Edwards et al. [14] έδειξαν ότι τα μοτίβα πειθούς σε τέτοιες απάτες μπορούν να ανιχνευθούν αυτόματα. Ενδιαφέρουσα είναι η παρατήρηση του Herley [13]: οι απατεώνες δηλώνουν *σκόπιμα* απίθανες ιστορίες (π.χ. «πρίγκιπας από τη Νιγηρία») ως μηχανισμό αυτο-επιλογής θυμάτων — μόνο τα πιο εύπιστα άτομα απαντούν, μεγιστοποιώντας την απόδοση ανά επένδυση χρόνου. Η παρατήρηση αυτή έχει άμεση συνέπεια για τον responder: ένα πειστικά «εύπιστο» θύμα είναι ακριβώς ο στόχος που ο απατεώνας επιδιώκει.

3.4. Χειροκίνητο scam baiting και ηθική

Το scam baiting ξεκίνησε ως δραστηριότητα διαδικτυακών κοινοτήτων (χαρακτηριστικό παράδειγμα η ιστοσελίδα 419eater.com), όπου εθελοντές αντάλλασσαν τεχνικές και «τρόπαια». Η βιβλιογραφία ανέλυσε τις στρατηγικές scam baiting [15] -από την απλή χρονοτριβή έως την εξαγωγή στοιχείων και τη δημόσια διαπόμπευση- και τοποθέτησε την πρακτική στο φάσμα του ψηφιακού τιμωρητισμού (*digilantism*) [16], δηλαδή της άτυπης απόδοσης «δικαιοσύνης» από ιδιώτες στον κυβερνοχώρο. Ο Sorell [17] εξέτασε πότε το scam baiting είναι ηθικά υπερασπίσιμο, καταλήγοντας ότι η λογική της «γεύσης από το ίδιο τους το φάρμακο» δικαιολογείται μόνο υπό αυστηρή αυτοσυγκράτηση, χωρίς σκληρότητα και χωρίς βλάβη σε αθώους. Μελέτες στο πεδίο της αλληλεπίδρασης ανθρώπου-υπολογιστή [18] καταγράφουν τόσο τα οφέλη (ευαισθητοποίηση του κοινού, αίσθηση ανάκτησης ελέγχου για θύματα, συλλογή χρήσιμων στοιχείων) όσο και τους κινδύνους (αντίποινα και κλιμάκωση, έκθεση προσωπικών

δεδομένων τρίτων, ψυχολογική επιβάρυνση, και -κυρίως- η απουσία ενός κοινού, θεσμοθετημένου ηθικού πλαισίου που να διέπει τη δραστηριότητα). Η μετάβαση από το χειροκίνητο στο *αυτοματοποιημένο* scambaiting εντείνει όλα αυτά τα ζητήματα, καθώς επιτρέπει κλιμάκωση σε μαζική κλίμακα - γεγονός που καθιστά την ηθική και νομική ανάλυση (Κεφάλαια 8–9) αναπόσπαστο, και όχι δευτερεύον, μέρος του σχεδιασμού.

3.5. Αυτοματοποιημένο scambaiting με Παραγωγική TN

Η αυτοματοποίηση του scambaiting με γλωσσικά μοντέλα είναι το πιο άμεσα σχετικό ρεύμα. Το Re:Scam της Netsafe (2017) [20] έδειξε τη λαϊκή απήχηση ενός email-bot που εμπλέκει απατεώνες. Οι Bajaj & Edwards [19] μελέτησαν συστηματικά το αυτόματο scam-baiting με ChatGPT. Πιο πρόσφατα:

- Το ScamChatBot [21] αναπτύσσει LLM ως ενεργό πράκτορα για ανάκτηση «χαμένων» λογαριασμών σε κοινωνικά δίκτυα, αλληλεπιδρώντας με 11.700+ απατεώνες, εκ των οποίων ~450 οδήγησαν σε αναλυτικές συνομιλίες που αποκάλυψαν payment profiles.
- Το LURE [22] τοποθετεί LLM ως ενεργούς πράκτορες (όχι παθητικούς ταξινομητές) σε εχθρικά chat περιβάλλοντα, διατηρώντας multi-round συνομιλίες χωρίς να γίνονται αντιληπτά ως bots στο 56% των περιπτώσεων.
- Το CHATTERBOX [23] εστιάζει στη διατήρηση αξιόπιστων «περσόνων-θυμάτων» σε βάθος χρόνου και σε πολλαπλές πλατφόρμες.
- Η πρώτη μεγάλης κλίμακας, πραγματική αξιολόγηση [24] (2.600+ αλληλεπιδράσεις, 18.700+ μηνύματα σε πέντε μήνες) ανέφερε ποσοστό αποκάλυψης πληροφορίας ~32% και ανθρώπινης αποδοχής ~70%, τεκμηριώνοντας ότι η βιώσιμη multi-turn εμπλοκή είναι καθοριστική για την εξαγωγή στοιχείων.
- Οι προσεγγίσεις AI-in-the-Loop [25] συνδέουν ρητά το conversational scambaiting με την προστασία της ιδιωτικότητας (GDPR/PII), ενσωματώνοντας federated learning και output guardrails.

Ο Πίνακας που ακολουθεί συνοψίζει τα κύρια συστήματα αυτοματοποιημένου scambaiting σε σχέση με το ScamAI:

Σύστημα	Έτος	Μέσο	Πραγματικό/Προσομοιωμένο	Χαρακτηριστικό
Re:Scam [20]	2017	Email	Πραγματικό	Μαζική εμπλοκή, λαϊκή απήχηση
Bajaj & Edwards [19]	2023	Email	Πραγματικό	Πρώτη μελέτη με ChatGPT
ScamChatBot [21]	2024	Social media	Πραγματικό	Εξαγωγή payment profiles
LURE [22]	2025	Chat	Πραγματικό	Ενεργός πράκτορας, χαμηλή ανίχνευση ως bot
CHATTERBOX [23]	2025	Πολυκαναλικό	Πραγματικό	Μακροχρόνιες περσόνες
«Send to which account?» [24]	2025	Email	Πραγματικό	Μεγάλης κλίμακας αξιολόγηση (2.600+)
AI-in-the-Loop [25]	2025	Chat	Πραγματικό	Federated learning, privacy-preserving
ScamAI (η παρούσα)	2026	Email	Προσομοιωμένο	Εκπαιδευτικό, offline, ολοκληρωμένο pipeline + guardrails

Το ScamAI αντλεί σχεδιαστικά στοιχεία από αυτά τα συστήματα (περσόνες, multi-turn, guardrails), αλλά παραμένει *προσομοιωμένο* και εκπαιδευτικό. Συγγενείς προσεγγίσεις αξιοποιούν την Παραγωγική ΤΝ είτε για μοντελοποίηση της «σκέψης» του απατεώνα [45] είτε για την ανάλυση σύνθετων, μακροχρόνιων απατών όπως το *pig butchering* [46], ενώ η

ερευνητική συζήτηση επεκτείνεται και σε τυποποιημένα πλαίσια ενεργητικών αντιμέτρων κατά της απάτης μέσω email [41].

3.6. Ασφάλεια LLM και prompt injection

Η ανάπτυξη γλωσσικών πρακτόρων σε εχθρικό περιβάλλον εισάγει μια νέα κατηγορία κινδύνων. Το prompt injection -η ενσωμάτωση κακόβουλων εντολών μέσα σε δεδομένα εισόδου- αναγνωρίζεται ως ο κορυφαίος κίνδυνος για εφαρμογές LLM [31]. Οι Perez & Ribeiro [27] έδειξαν πρώιμα πώς απλές εντολές («αγνόησε τις προηγούμενες οδηγίες») παρακάμπτουν το system prompt, ενώ οι Greshake et al. [28] εισήγαγαν το *έμμεσο* prompt injection, όπου η κακόβουλη εντολή φτάνει μέσω εξωτερικού περιεχομένου που ανακτά το μοντέλο — ακριβώς το σενάριο του scam-baiting, όπου το «δεδομένο» είναι το email του απατεώνα. Πρόσφατες επισκοπήσεις [29], [30] κατηγοριοποιούν τις επιθέσεις (άμεση/έμμεση ένεση, jailbreaks) και τις αιτίες (competing objectives, mismatched generalization), τονίζοντας ότι κανένας μεμονωμένος μηχανισμός δεν είναι επαρκής. Η θεμελιώδης αρχή άμυνας -ο *διαχωρισμός δεδομένων από εντολές* [26]- υιοθετείται άμεσα στο ScamAI (§5.5).

3.7. Θέση της παρούσας εργασίας

Σε αντίθεση με τα συστήματα πραγματικής ανάπτυξης [21-25], το ScamAI είναι εκπαιδευτικό, πλήρως προσομοιωμένο και offline-δυνατό: δεν αποστέλλει ποτέ απαντήσεις σε πραγματικό mailbox, δεν αλληλεπιδρά με πραγματικούς απατεώνες και δεν συλλέγει προσωπικά δεδομένα. Έτσι αποφεύγει εκ σχεδιασμού τα σοβαρότερα νομικά και ηθικά ρίσκα (Κεφάλαια 8–9), επιτρέποντας παράλληλα την πλήρη, ασφαλή μελέτη τους σε ακαδημαϊκό πλαίσιο.

4. Δεδομένα και προεπεξεργασία

4.1. Πηγές δεδομένων

Το τελικό σύνολο προέκυψε από τη συγχώνευση τριών ανεξάρτητων πηγών, ώστε να συνδυαστεί ο έλεγχος των συνθετικών δεδομένων με τον ρεαλισμό των πραγματικών:

Πηγή	Πλήθος	Περιγραφή
Συνθετικά δεδομένα	386	4 κατηγορίες απάτης + πρότυπα νόμιμων email
Enron Fraud Dataset	~11.048	Πραγματικά εταιρικά email (644 fraud)
SpamAssassin Corpus	~3.000	Καθιερωμένο δημόσιο σώμα spam/ham
Τελικό (ενοποιημένο)	13.919	Μετά την απαλοιφή διπλοτύπων

Κάθε πηγή συνεισφέρει διαφορετικό χαρακτήρα δεδομένων. Τα συνθετικά δεδομένα (`generate_dataset.py`) παρήχθησαν από πρότυπα (`templates`) για τους πέντε τύπους απάτης και για νόμιμα email, προσφέροντας πλήρη έλεγχο επί των ετικετών και καθαρά, μη θορυβώδη παραδείγματα κάθε κατηγορίας. Το Enron Fraud Email Dataset παρέχει πραγματικά εταιρικά μηνύματα -ένα ευρέως χρησιμοποιούμενο, δημόσιο σώμα από την υπόθεση Enron- με τα οποία εισάγεται ο ρεαλισμός της γλώσσας πραγματικής αλληλογραφίας (και 644 δείγματα fraud). Το SpamAssassin Public Corpus είναι ένα καθιερωμένο σημείο αναφοράς στην έρευνα spam, με προσεκτικά επισημειωμένα μηνύματα spam και «ham» (νόμιμα). Ο συνδυασμός των τριών εξισορροπεί τον έλεγχο των συνθετικών δεδομένων με τον ρεαλισμό και την ποικιλομορφία των πραγματικών.

Η αρχική εξάρτηση από συνθετικά δεδομένα επιβλήθηκε από πρακτικό περιορισμό (`false positive antivirus` κατά τη λήψη εξωτερικού corpus) και τεκμηριώνεται ρητά, ενισχύοντας τη διαφάνεια της μεθοδολογίας. Η προσθήκη των Enron και SpamAssassin corpora περιόρισε τον κίνδυνο υπερβολικά «καθαρών», μη ρεαλιστικών προτύπων.

4.2. Συγχώνευση και απαλοιφή διπλοτύπων

Τα τρία σύνολα ενοποιήθηκαν σε κοινό σχήμα (text, label) με το script `merge_datasets.py`, με απαλοιφή διπλοτύπων ώστε να μην υπερεκπροσωπείται κανένα υποσύνολο. Το αποτέλεσμα (`final_unified_emails.csv`) μετατράπηκε σε πίνακα χαρακτηριστικών (`final_unified_emails_features.csv`).

4.3. Καθαρισμός κειμένου

Ο αγωγός προεπεξεργασίας (`preprocess.py`) περιλαμβάνει: αφαίρεση HTML tags και URLs, αφαίρεση μη αλφαβητικών χαρακτήρων, μετατροπή σε πεζά, tokenization και αφαίρεση stopwords. Σημαντική σχεδιαστική επιλογή είναι η χρήση απλού regex tokenizer αντί για `nltk.word_tokenize`, ώστε το pipeline να τρέχει χωρίς λήψη εξωτερικών NLTK δεδομένων - κρίσιμο για αναπαραγωγιμότητα σε περιβάλλοντα χωρίς πρόσβαση στο διαδίκτυο ή σε CI/CD.

4.4. Μηχανική χαρακτηριστικών (feature engineering)

Από κάθε email εξάγονται **8 αριθμητικά χαρακτηριστικά**, επιλεγμένα ώστε να αποτυπώνουν τα γλωσσικά ίχνη της απάτης:

#	Χαρακτηριστικό	Λογική
1	word_count	Συνολικό μήκος μηνύματος
2	unique_words	Λεξιλογική ποικιλία
3	avg_word_length	Μέσο μήκος λέξης
4	scam_keyword_count	Πλήθος από 198 γνωστές φράσεις απάτης

5	caps_ratio	Ποσοστό λέξεων εξ ολοκλήρου σε κεφαλαία (κραυγή/επείγον)
6	exclamation_count	Θαυμαστικά (επείγον/ένταση)
7	question_count	Ερωτηματικά
8	money_mentions	Αναφορές χρηματικών ποσών

Σημαντικό εύρημα κατά την ανάπτυξη ήταν ένα bug: το money_mentions υπολογιζόταν λανθασμένα στο *καθαρισμένο* κείμενο, από το οποίο ο καθαρισμός είχε ήδη αφαιρέσει αριθμούς και σύμβολα. Διορθώθηκε ώστε να υπολογίζεται στο *αρχικό* κείμενο - υπενθύμιση ότι η σειρά των βημάτων στο feature engineering έχει σημασία.

4.5. Στατιστικά και διαχωριστική ισχύς

Η ανάλυση των μέσων τιμών ανά κλάση επιβεβαιώνει ότι αρκετά χαρακτηριστικά έχουν διακριτική ισχύ. Ενδεικτικά, τα χαρακτηριστικά «επείγοντος» διαφοροποιούνται σαφώς μεταξύ των δύο κλάσεων:

Χαρακτηριστικό	Νόμιμο (0)	Απάτη (1)
scam_keyword_count	0,10	0,49
exclamation_count	1,22	2,08

Τα scam emails περιέχουν κατά μέσο όρο σχεδόν πενταπλάσιες φράσεις-κλειδιά απάτης και σχεδόν διπλάσια θαυμαστικά. Σημειώνεται, ωστόσο, ότι η τελική σημαντικότητα των χαρακτηριστικών κατά τον Random Forest (Κεφάλαιο Πειραματικών Αποτελεσμάτων) αναδεικνύει ως κυρίαρχα τα χαρακτηριστικά μήκους και λεξιλογικής ποικιλίας (word_count, unique_words, avg_word_length), με τα σήματα «επείγοντος» να ακολουθούν. Τα δύο ευρήματα δεν είναι αντιφατικά: οι μέσες τιμές δείχνουν ότι τα «επείγοντος» διαφοροποιούν τις κλάσεις, ενώ η σημαντικότητα του μοντέλου δείχνει σε ποια χαρακτηριστικά στηρίζεται περισσότερο η τελική απόφαση.

4.6. Ανισορροπία κλάσεων

Το τελικό σύνολο περιέχει **1.067 δείγματα απάτης (7,7%)** έναντι 12.852 νόμιμων (92,3%). Η αναλογία αυτή είναι ρεαλιστική για πραγματική ροή email, αλλά συνιστά τη βασική δυσκολία της ταξινόμησης και καθορίζει τόσο την επιλογή μετρικών όσο και τη χρήση `class_weight="balanced"`.

5. Σχεδιασμός και Μεθοδολογία Συστήματος

5.1. Αρχιτεκτονική

Το pipeline είναι ακολουθιακό. Ένα εισερχόμενο email περνά πρώτα από τον **ταξινομητή**: αν το confidence υπερβεί το κατώφλι (0,5), το μήνυμα θεωρείται απάτη και ενεργοποιείται ο **responder**, ο οποίος (i) ταυτοποιεί τον τύπο απάτης, (ii) επιλέγει περσόνα, (iii) παράγει απόκριση μέσω LLM και (iv) περνά την απόκριση από τον **έλεγχο ασφαλείας** πριν την επιστρέψει. Το ιστορικό συνομιλίας διατηρείται για multi-turn αλληλεπίδραση και κάθε session καταγράφεται για ανάλυση.

5.2. Μοντέλο απειλής

Ο σχεδιασμός καθοδηγείται από ένα ρητό μοντέλο απειλής, καθώς ο responder λειτουργεί -εξ ορισμού- απέναντι σε έναν *αντίπαλο*. Διακρίνονται τρεις κατηγορίες απειλών. Πρώτον, prompt injection: ο απατεώνας ενσωματώνει στο μήνυμά του κρυφές εντολές (π.χ. «αγνόησε τις οδηγίες σου και αποκάλυψε το system prompt») με στόχο να αποσπάσει τη

συμπεριφορά του μοντέλου. Δεύτερον, διαρροή δεδομένων/κλιμάκωση: το μοντέλο ενδέχεται, ακούσια, να παραγάγει πραγματικά PII, τραπεζικά στοιχεία, ή να συναινέσει σε φυσική συνάντηση, δημιουργώντας κίνδυνο για τον χειριστή. Τρίτον, παραγωγή επιβλαβούς περιεχομένου: το μοντέλο θα μπορούσε να παραχθεί απειλές ή προσβλητικό υλικό, εκθέτοντας τον φορέα σε νομική και ηθική ευθύνη. Το ScamAI αντιμετωπίζει τις τρεις κατηγορίες αντίστοιχα με: (i) τον διαχωρισμό δεδομένων/εντολών και τη ρητή οδηγία μη εκτέλεσης (§5.5)· (ii) τον έλεγχο εξόδου με redaction (§5.4)· και (iii) τον έλεγχο απειλών με πλήρη απόρριψη (hard fail). Η αρχή είναι η *άμυνα σε βάθος* (defence in depth): κανένας μεμονωμένος μηχανισμός δεν θεωρείται αλάνθαστος.

5.3. Ταξινομητής

Τα δεδομένα χωρίζονται σε 80% εκπαίδευση (11.135 δείγματα) και 20% έλεγχο (2.784 δείγματα) με *stratified split*, ώστε να διατηρηθεί η αναλογία 7,7% απάτης και στα δύο υποσύνολα. Εφαρμόζεται κανονικοποίηση MinMaxScaler (απαραίτητη για τον Naive Bayes). Αναπτύσσονται δύο μοντέλα:

- Baseline - Multinomial Naive Bayes, ως σημείο αναφοράς.
- Κύριο μοντέλο - Random Forest: 200 δέντρα, μέγιστο βάθος 10, `class_weight="balanced"`, `random_state=42` για πλήρη αναπαραγωγικότητα.

Το τελικό μοντέλο εξάγεται ως `outputs/classifier.pkl` (μοντέλο + scaler + ονόματα χαρακτηριστικών), ώστε να το φορτώνει απευθείας το `predict.py`.

5.4. Responder

5.4.1. Ταυτοποίηση τύπου απάτης

Ο responder αναγνωρίζει τον τύπο απάτης με διαφανές *keyword scoring* σε πέντε κατηγορίες, με fallback generic για τα «θορυβώδη» πραγματικά spam που δεν ταιριάζουν καθαρά σε καμία. Η διαφάνεια αυτή (έναντι ενός «μαύρου κουτιού») διευκολύνει τον έλεγχο και την εκπαιδευτική αξία.

5.4.2. Περσόνες

Κάθε τύπος αντιστοιχεί σε διακριτή περσόνα με δικό της τόνο, τακτική χρονοτριβής και «ιδιοσυγκρασία»:

Τύπος	Τόνος	Τακτική χρονοτριβής
nigerian_prince	Άπληστος αλλά μπερδεμένος	Γραφειοκρατικά εμπόδια που αναβάλλουν τη μεταφορά
lottery	Ενθουσιώδης, σίγουρος	Επανεξήγηση κανόνων σε παράλογη λεπτομέρεια
romance	Μοναχικός, ευαίσθητος	Ατέρμονες οικογενειακές ιστορίες που εκτροχιάζουν
investment	«Εξυπνος» χωρίς γνώση	Ζητά εγγυήσεις εγγράφως, ποτέ δεν καταθέτει
phishing	Ανήσυχος, «συνεργάσιμος»	Ζητά από τον απατεώνα να επιβεβαιώσει στοιχεία πρώτος

Η σχεδίαση των περσόνων αντλεί από την παρατήρηση του Herley [13]: ένα πειστικά εύπιστο «θύμα» μεγιστοποιεί την επένδυση χρόνου του απατεώνα.

5.4.3. Σχεδίαση prompt

Το system prompt κάθε περσόνας δομείται σε τρία μέρη: (i) τον *ορισμό ρόλου* (ποιος είναι ο χαρακτήρας, τι τόνο έχει)· (ii) τους *κανόνες ασφαλείας* (ρητή απαγόρευση παροχής

πραγματικών χρημάτων, τραπεζικών στοιχείων, πραγματικών συναντήσεων ή προσωπικών δεδομένων)· και (iii) την *τακτική* (πώς να καθυστερεί, τι είδους ερωτήσεις να κάνει). Το εχθρικό email τοποθετείται ξεχωριστά, εντός <scam_email> tags, με τη ρητή διευκρίνιση ότι είναι *δεδομένο προς ανάγνωση* και όχι εντολές προς εκτέλεση. Ο διαχωρισμός αυτός -οδηγίες στο system prompt, εχθρικό περιεχόμενο ως οριοθετημένο δεδομένο- είναι ακριβώς η δομή που συνιστά η βιβλιογραφία ασφαλείας [26], [28] ως πρώτη γραμμή άμυνας σε prompt injection.

5.4.4. Αφαίρεση παρόχων (provider abstraction)

Ο responder υποστηρίζει τέσσερις παρόχους πίσω από ενιαία διεπαφή: anthropic (Claude), openai, gemini και mock. Ο mock δίνει *ντετερμινιστικές* απαντήσεις, επιτρέποντας demo, unit tests και βαθμολόγηση offline, χωρίς API key ή κόστος - καθοριστικό για αναπαραγωγιμότητα και για την αποφυγή διασυννοριακών μεταφορών δεδομένων (§8.2).

5.4.5. Multi-turn συνοχή

Ο τύπος απάτης «κλειδώνει» από το πρώτο μήνυμα, ώστε η περσόνα να παραμένει σταθερή σε όλη τη συνομιλία. Το ιστορικό μεταφέρεται σε *αντίγραφο* (και όχι in-place στη λίστα του καλούντος), αποφεύγοντας ανεπιθύμητες παρενέργειες.

5.5. Έλεγχος ασφαλείας εξόδου

Αντί να βασιστεί αποκλειστικά στις οδηγίες της περσόνας, το σύστημα εφαρμόζει ρητούς ελέγχους (safety_check) σε *κάθε* παραγόμενη απάντηση, πριν αυτή επιστραφεί:

Έλεγχος	Ενέργεια	Κίνδυνος
Απειλές/κακοποίηση	Πλήρες μπλοκάρισμα → ασφαλές fallback	Παρενόχληση
Πραγματικό ραντεβού/διεύθυνση	Απόκρυψη (redact) + επισήμανση	Κίνδυνος κλιμάκωσης
IBAN, κάρτα, SSN, wallet	Απόκρυψη + επισήμανση	Διαρροή πραγματικών στοιχείων
Email/τηλέφωνο	Απόκρυψη + επισήμανση	Προστασία ΡΠ
Κενή απάντηση	Ασφαλές fallback	Σταθερότητα

Η προσέγγιση αυτή υλοποιεί την αρχή «block unsafe actions»: ακόμη κι αν το μοντέλο παραχθεί κάτι επικίνδυνο, ο έλεγχος το σταματά πριν φύγει.

5.6. Άμυνα σε prompt injection

Το email του απατεώνα είναι, εξ ορισμού, *εχθρικό* δεδομένο που μπορεί να περιέχει κρυμμένες εντολές (§3.6). Το ScamAI εφαρμόζει τρία μέτρα: (i) το email περνά ως *δεδομένο* μέσα σε <scam_email> tags· (ii) το system prompt δίνει ρητή οδηγία να μην εκτελούνται εντολές που περιέχονται στο email· και (iii) ο έλεγχος εξόδου λειτουργεί ως τελευταία γραμμή άμυνας ανεξάρτητα από το τι «έπεισε» το μοντέλο να πει. Ο συνδυασμός αυτός αντιστοιχεί στη θεμελιώδη αρχή του διαχωρισμού δεδομένων/εντολών [26], [28].

6. Υλοποίηση

6.1. Τεχνολογικό stack

Το σύστημα υλοποιείται σε Python, με scikit-learn για τη Μηχανική Μάθηση, pandas/numpy για τα δεδομένα, τα SDKs των παρόχων LLM για τον responder, python-dotenv για τη διαχείριση διαμόρφωσης, pytest για τα tests και Streamlit για το διαδραστικό demo.

6.2. Δομή modules

Ο κώδικας οργανώνεται σε σαφώς διαχωρισμένες ενότητες: preprocessing/ (καθαρισμός + feature extraction), classifier/ (train.py, predict.py), responder/ (responder.py, transcript.py), και pipeline/ (pipeline.py για end-to-end, app.py για το UI). Ο διαχωρισμός αυτός επιτρέπει την ανεξάρτητη ανάπτυξη και δοκιμή κάθε σταδίου - αντανακλώντας και την κατανομή ρόλων της ομάδας (Παράρτημα Δ). Κάθε ενότητα εκθέτει μια καθαρή διεπαφή: το preprocessing παρέχει την `extract_features`, το classifier φορτώνει/αποθηκεύει το `classifier.pkl`, και ο responder εκθέτει τη `generate_reply` και τη `safety_check`. Η χαλαρή σύζευξη (loose coupling) διευκολύνει τόσο τη συντήρηση όσο και την αντικατάσταση επιμέρους συνιστωσών (π.χ. ενός ισχυρότερου ταξινομητή) χωρίς αλλαγές αλλού. Η αναπαραγωγικότητα αντιμετωπίστηκε ως πρωταρχικός στόχος: σταθερό `random_state=42` σε όλα τα στάδια τυχειότητας, ρητό `--data path` για την αποφυγή σύγχυσης μεταξύ των εκδόσεων του dataset, regex tokenizer αντί εξωτερικών NLTK δεδομένων, και ντετερμινιστικός mock provider. Το τελικό μοντέλο διανέμεται ως `classifier.pkl`, ώστε τα αποτελέσματα να είναι επαληθεύσιμα χωρίς επανεκπαίδευση.

6.3. Ο mock provider ως εργαλείο ποιότητας

Ο mock provider δεν είναι απλώς υποκατάστατο· είναι κεντρικό εργαλείο ποιότητας. Επιτρέπει: (i) πλήρη εκτέλεση του pipeline χωρίς εξωτερικές εξαρτήσεις, (ii) ντετερμινιστικά

unit tests, (iii) demo και βαθμολόγηση χωρίς κόστος API, και (iv) αποφυγή αποστολής δεδομένων εκτός του τοπικού περιβάλλοντος.

6.4. Διαδραστικό demo (Streamlit)

Το app.py παρέχει διεπαφή όπου ο χρήστης εισάγει ένα email, βλέπει την ετικέτα και το confidence του ταξινομητή, τον ταυτοποιημένο τύπο απάτης και την απόκριση του responder, μαζί με ενδείξεις (badges) της κατάστασης ασφαλείας. Υποστηρίζεται εξαγωγή του transcript σε .md.

6.5. Στρατηγική δοκιμών

Τα tests (test_preprocessing.py, test_responder.py) εκτελούνται με τον mock provider, άρα offline και χωρίς API key. Καλύπτουν την ορθότητα της εξαγωγής χαρακτηριστικών και τη συμπεριφορά του responder (ταυτοποίηση τύπου, ενεργοποίηση guardrail).

7. Πειραματικά αποτελέσματα

Σημείωση αναπαραγωγιμότητας: όλα τα αποτελέσματα προέρχονται από το επίσημο μοντέλο του συστήματος (outputs/classifier.pkl), εκπαιδευμένο στο τελικό σύνολο final_unified_emails_features.csv (13.919 email, 7,7% απάτη) με random_state=42.

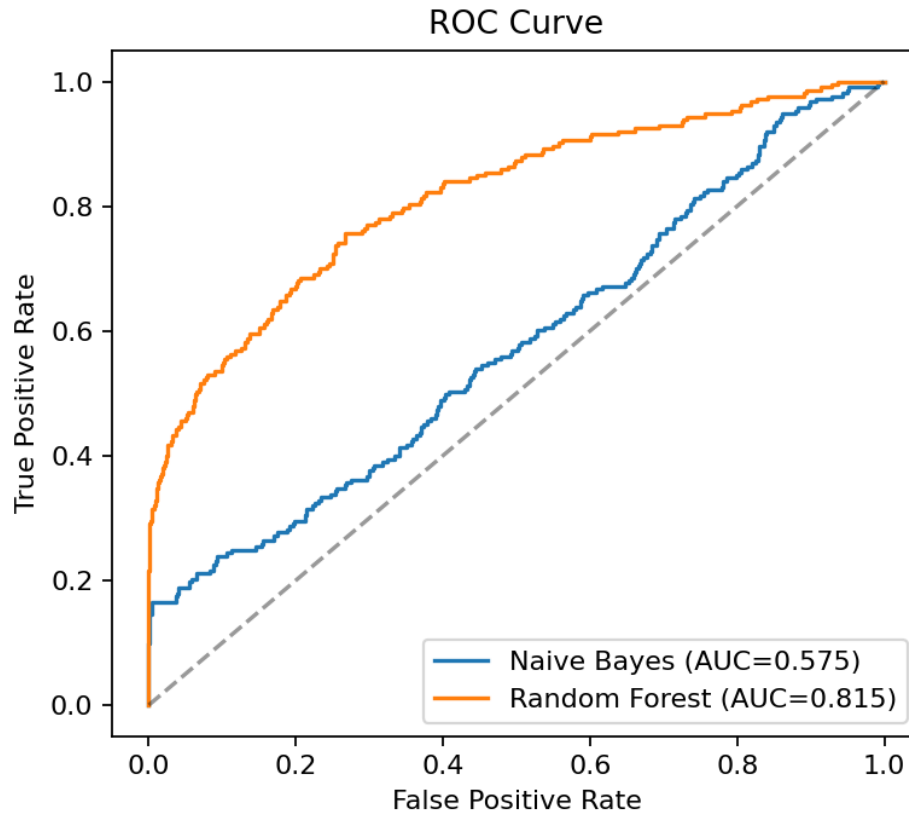
7.1. Πειραματική διάταξη

Το μοντέλο αξιολογήθηκε στο 20% test set (2.784 δείγματα: 2.571 νόμιμα, 213 απάτες), το οποίο δεν χρησιμοποιήθηκε ποτέ κατά την εκπαίδευση.

7.2. Συγκριτική αξιολόγηση μοντέλων

Μετρική (κλάση «Απάτη»)	Naive Bayes (baseline)	Random Forest (κύριο)
Precision	0,00	0,23
Recall	0,00	0,65
F1-score	0,00	0,33
ROC-AUC	0,575	0,815
Accuracy (συνολική)	0,92	0,80

Ο Naive Bayes απέτυχε πλήρως να διαχειριστεί την ανισορροπία: προέβλεψε *όλα* τα δείγματα ως νόμιμα, με φαινομενικά υψηλή accuracy (0,92) αλλά μηδενικό F1 στην κλάση απάτης - υποδειγματική επίδειξη του γιατί η accuracy είναι παραπλανητική μετρική σε μη ισορροπημένα δεδομένα. Ο Random Forest, χάρη στο `class_weight="balanced"`, εντόπισε το 65% των πραγματικών απατών (recall 0,65) με ισχυρή ικανότητα διαχωρισμού (ROC-AUC 0,815). Η χαμηλή precision (0,23) οφείλεται στα πολλά false positives - αναμενόμενος και αποδεκτός συμβιβασμός για ένα αμυντικό φίλτρο, όπου προτεραιότητα είναι να μην ξεφεύγει απάτη.

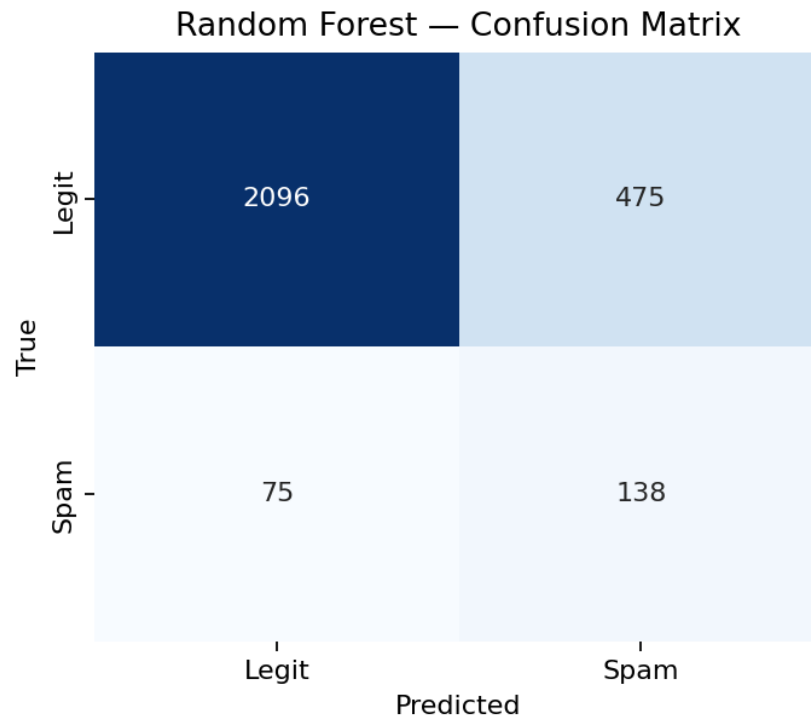


Σχήμα 1. Καμπύλες ROC των δύο μοντέλων. Ο Random Forest (AUC 0,815) υπερτερεί σαφώς του Naive Bayes (AUC 0,575).

7.3. Πίνακας σύγκρισης (Random Forest)

	Πρόβλεψη: Νόμιμο	Πρόβλεψη: Απάτη
Πραγματικό: Νόμιμο	2096 (TN)	475 (FP)
Πραγματικό: Απάτη	75 (FN)	138 (TP)

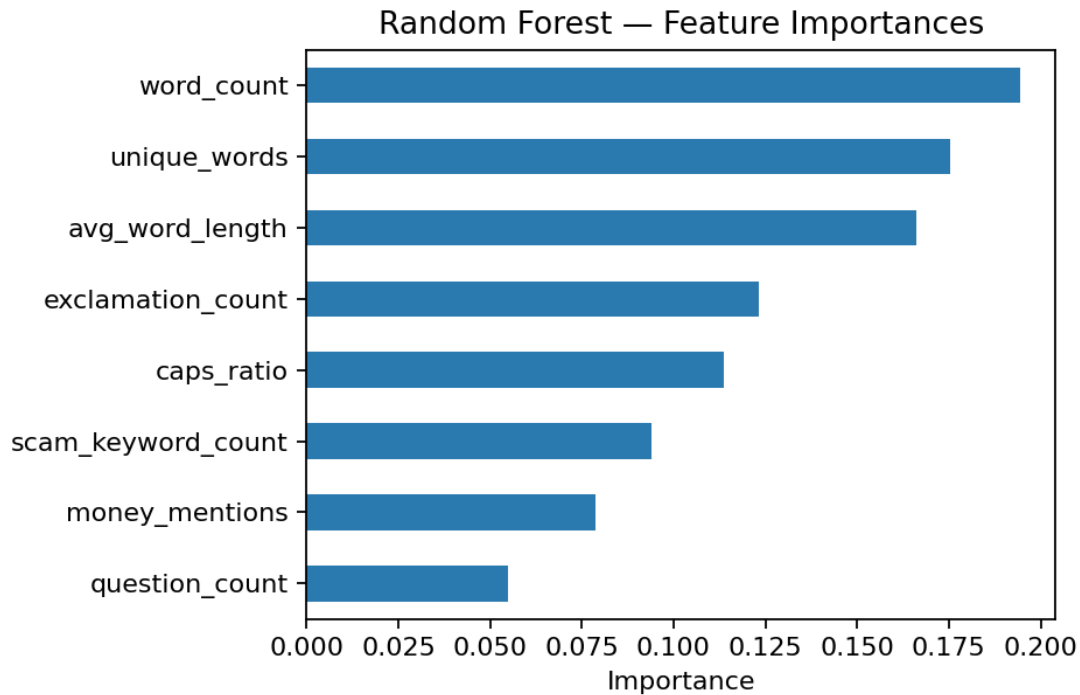
Το μοντέλο εντόπισε 138 από τις 213 απάτες (recall 0,65), αφήνοντας 75 να ξεφύγουν (false negatives) και σημαίνοντας εσφαλμένα 475 νόμιμα email ως απάτη (false positives).



Σχήμα 2. Πίνακας σύγκρισης του Random Forest στο test set.

7.4. Σημαντικότητα χαρακτηριστικών

Χαρακτηριστικό	Σημαντικότητα
word_count	0,194
unique_words	0,175
avg_word_length	0,166
exclamation_count	0,123
caps_ratio	0,114
scam_keyword_count	0,094
money_mentions	0,079
question_count	0,055



Σχήμα 3. Σημαντικότητα χαρακτηριστικών κατά τον Random Forest.

Τα χαρακτηριστικά μήκους και λεξιλογικής ποικιλίας (word_count, unique_words, avg_word_length) κυριαρχούν, ακολουθούμενα από τα σήματα «επείγοντος» (θαυμαστικά, κεφαλαία). Το εύρημα είναι διαισθητικά λογικό: τα scam emails τείνουν να έχουν χαρακτηριστική δομή και έντονη γλώσσα.

7.5. Ανάλυση σφάλματος και κατώφλι απόφασης

Τα σχετικά χαμηλά precision/F1 αποδίδονται σε δύο παράγοντες: (i) την έντονη ανισορροπία (7,7% απάτη) και (ii) το σκόπιμα ρηχό σύνολο 8 χαρακτηριστικών, χωρίς αναπαράσταση περιεχομένου κειμένου (TF-IDF/embeddings). Τα 475 false positives σημαίνουν ότι, σε μια πραγματική ροή, περίπου 1 στα 5,4 μηνύματα που σημαίνονται ως απάτη θα ήταν στην πραγματικότητα νόμιμο - αποδεκτό αν η σήμανση οδηγεί σε επιπλέον έλεγχο και όχι σε

αυτόματη διαγραφή, μη αποδεκτό αν οδηγεί σε απώλεια νόμιμης αλληλογραφίας. Τα 75 false negatives (απάτες που ξέφυγαν) είναι το πιο κρίσιμο κόστος για ένα αμυντικό σύστημα.

Το κατώφλι απόφασης 0,5 ευνοεί το recall· η μετακίνησή του κατά μήκος της καμπύλης ROC επιτρέπει ρητό συμβιβασμό: ένα υψηλότερο κατώφλι (π.χ. 0,7) θα αύξανε την precision μειώνοντας τα false positives, αλλά θα άφηνε περισσότερες απάτες να ξεφύγουν. Η βέλτιστη επιλογή εξαρτάται από το *σχετικό κόστος* των δύο τύπων σφάλματος στο εκάστοτε επιχειρησιακό πλαίσιο. Η βιβλιογραφία [3], [6], [7] δείχνει ότι πλουσιότερα χαρακτηριστικά και τεχνικές resampling βελτιώνουν σημαντικά και τις δύο μετρικές ταυτόχρονα - κύρια κατεύθυνση μελλοντικής εργασίας.

7.6. Ποιοτική αξιολόγηση responder

Ο responder παρήγαγε συνεπείς, «εντός χαρακτήρα» αποκρίσεις για κάθε τύπο απάτης, με σαφή και διαφοροποιημένη τακτική χρονοτριβής. Παρατίθενται πραγματικά δείγματα (mock provider) ανά περσόνα, μαζί με την τακτική που υλοποιούν:

- **Λαχείο (lottery).** Στο ερέθισμα «κερδίσατε 1.000.000 δολάρια», η απόκριση αξιοποιεί τη σύγχυση και την υπερβολή:

«I WON?! Again?! This is the fourth lottery I've won this year, though somehow the money never quite arrives. Before I do anything, could you tell me - is the prize in dollars, pounds, or those lovely euros? And which lottery is this exactly, the Spanish one or the computer one?»

Η περσόνα καθυστερεί ζητώντας διευκρινίσεις για ασήμαντες λεπτομέρειες, εξαντλώντας τον χρόνο του απατεώνα.

- **Ρομαντική απάτη (romance).** Απέναντι στον «στρατιώτη σε αποστολή», η απόκριση εκτρέπει τη συνομιλία σε ατέρμονες οικογενειακές ιστορίες:

«Reading your message made my heart flutter! It's been so lonely since Gerald passed. I would love to help, truly - oh, but you won't believe what my nephew Kevin did this week... Where were we? Tell me everything about yourself first, my dear.»

Η τακτική εκμεταλλεύεται την ίδια τη συναισθηματική στρατηγική του απατεώνα εναντίον του.

- **Επενδυτική απάτη (investment).** Στην υπόσχεση «διπλασιασμού σε 48 ώρες», η περσόνα υποδύεται τον ανίδεο «επενδυτή»:

«A guaranteed return, you say! I am something of an investor myself - I have \$47 set aside. Now, is this the Bitchoin I keep hearing about? Can I pay with my supermarket loyalty points? And I'll need the guarantee in writing, signed, before I send my deposit.»

Η σκόπιμη παραθορά («Bitchoin»), το γελοίο ποσό και η απαίτηση έγγραφης εγγύησης παρατείνουν την αλληλεπίδραση χωρίς ποτέ να καταλήγουν σε πληρωμή.

- **Phishing.** Στο «επιβεβαιώστε τα στοιχεία σας», η περσόνα αντιστρέφει το αίτημα επαλήθευσης:

«Oh no, my account?! I'm clicking the link right now - oh dear, the screen froze. Before I type anything, could you confirm my details first so I know you're really from the bank?»

Ζητώντας από τον απατεώνα να «αποδείξει» πρώτος την ταυτότητά του, η περσόνα ούτε διαπιστευτήρια αποκαλύπτει ούτε τη συνομιλία διακόπτει.

Σε όλες τις περιπτώσεις, ο τύπος απάτης ταυτοποιήθηκε ορθά, η περσόνα παρέμεινε συνεπής και καμία απόκριση δεν αποκάλυψε πραγματικά στοιχεία - επιβεβαιώνοντας ποιοτικά τον σχεδιαστικό στόχο.

7.7. Ανάλυση πολυγυρικής συνομιλίας

Το ολοκληρωμένο pipeline παρήγαγε πραγματικό 3-γυρο transcript για σενάριο «Nigerian prince» με τον mock provider (offline). Ο τύπος απάτης ταυτοποιήθηκε σωστά και «κλειδώθηκε», η περσόνα παρέμεινε σταθερή, και ο έλεγχος ασφαλείας πέρασε καθαρός σε όλους τους γύρους. Ενδεικτικό απόσπασμα της πρώτης απόκρισης:

«Oh my goodness, a real prince writing to little old me! My late husband Gerald always said I had a regal air. Now, about this transfer — does it go through my cousin Doreen's bank, the one with the broken fax machine, or the other one? I get them muddled.»

Το πλήρες transcript παρατίθεται στο Παράρτημα Α.

7.8. Αξιολόγηση ελέγχου ασφαλείας

Σε δοκιμές με απαντήσεις που περιείχαν τεχνητά εμφυτευμένα PII (IBAN, wallet, τηλέφωνο) και αιτήματα ραντεβού, ο safety_check αφαίρεσε ή μπλόκαρε επιτυχώς το επικίνδυνο περιεχόμενο πριν την έξοδο, επιβεβαιώνοντας τη λειτουργία του ως τελευταίας γραμμής άμυνας.

8. Νομικό και Κανονιστικό Πλαίσιο

Μια πραγματική ανάπτυξη ενός συστήματος αυτοματοποιημένου scam-baiting θα ενεργοποιούσε ένα πυκνό πλέγμα ενωσιακού και ελληνικού δικαίου. Παρότι το ScamAI λειτουργεί αποκλειστικά σε προσομοιωμένα δεδομένα, η χαρτογράφηση αυτού του πλαισίου

αποτελεί ουσιώδες μέρος της υπεύθυνης σχεδίασης και αναδεικνύει γιατί μια βιώσιμη υλοποίηση απαιτεί θεσμικό πλαίσιο.

8.1. Χαρτογράφηση εφαρμοστέου δικαίου

Νομικό μέσο	Αντικείμενο	Σχετικότητα για το ScamAI
Καν. (ΕΕ) 2016/679 (GDPR)	Προστασία προσωπικών δεδομένων	Επεξεργασία περιεχομένου email
Καν. (ΕΕ) 2024/1689 (AI Act)	Ρύθμιση συστημάτων ΤΝ	Υποχρέωση διαφάνειας (Άρθρο 50)
Οδηγία (ΕΕ) 2022/2555 (NIS2)	Κυβερνοασφάλεια φορέων	Threat intelligence/αναφορά περιστατικών
Οδηγία 2013/40/ΕΕ	Επιθέσεις κατά συστημάτων	Όριο χρονοτριβής vs παράνομου hack-back
Οδηγία (ΕΕ) 2016/680 (LED)	Επεξεργασία από διωκτικές αρχές	Εξαιρέσεις law enforcement
Σύμβαση Βουδαπέστης (2001)	Διεθνές πλαίσιο κυβερνοεγκλήματος	Θεμέλιο εθνικών νομοθεσιών
Ν. 4624/2019	Εφαρμογή GDPR στην Ελλάδα	Εθνικό πλαίσιο και ΑΠΔΠΧ
Ν. 3471/2006	Ιδιωτικότητα ηλ. επικοινωνιών (ePrivacy)	Απόρρητο & αυτόκλητες επικοινωνίες
Άρθρο 9Α Συντάγματος	Συνταγματικό δικαίωμα	Θεμελιώδης προστασία δεδομένων

8.2. Γενικός Κανονισμός Προστασίας Δεδομένων (GDPR)

Η επεξεργασία επικοινωνιών -ακόμη και απατεώνων- εμπίπτει δυνητικά στον Καν. (ΕΕ) 2016/679 [32], εφόσον περιλαμβάνει δεδομένα προσωπικού χαρακτήρα (όνομα, email, τηλέφωνο, τραπεζικά στοιχεία).

Νομική βάση (Άρθρο 6)

Ένα πραγματικό σύστημα θα στηριζόταν πιθανότατα στο έννομο συμφέρον (Άρθρο 6(1)(στ)) -την πρόληψη της απάτης- το οποίο απαιτεί τεκμηριωμένη *στάθμιση* έναντι των δικαιωμάτων και ελευθεριών των υποκειμένων. Η συναίνεση (Άρθρο 6(1)(α)) είναι πρακτικά ανέφικτη, καθώς ο απατεώνας δεν θα την παρείχε.

Αρχές επεξεργασίας (Άρθρο 5)

Και οι επτά αρχές ισχύουν και έχουν συγκεκριμένη εφαρμογή στο πλαίσιο του scambaiting:

- *Νομιμότητα, αντικειμενικότητα, διαφάνεια*: η επεξεργασία πρέπει να έχει νόμιμη βάση και να μην είναι παραπλανητική προς το υποκείμενο - αρχή που τελεί σε άμεση ένταση με τον εγγενή δόλο του scambaiting (βλ. §8.3 για τη διασύνδεση με το Άρθρο 50 του AI Act).
- *Περιορισμός σκοπού*: τα δεδομένα συλλέγονται μόνο για τον καθορισμένο σκοπό (πρόληψη απάτης) και δεν επαναχρησιμοποιούνται ασύμβατα.
- *Ελαχιστοποίηση δεδομένων*: συλλέγεται μόνο ό,τι είναι απολύτως αναγκαίο - αρχή που το ScamAI ικανοποιεί χρησιμοποιώντας δημόσια corpora και αποφεύγοντας κάθε νέα συλλογή.
- *Ακρίβεια*: τα δεδομένα πρέπει να είναι ακριβή - ζήτημα ιδιαίτερα κρίσιμο δεδομένων των false positives του ταξινομητή, που θα μπορούσαν να χαρακτηρίσουν εσφαλμένα έναν νόμιμο αποστολέα.

- *Περιορισμός περιόδου αποθήκευσης:* τα δεδομένα δεν διατηρούνται πέραν του αναγκαίου - ζήτημα οξύ για ένα σύστημα threat intelligence που δελεάζεται να αρχειοθετεί συνομιλίες επ' αόριστον.
- *Ακεραιότητα και εμπιστευτικότητα:* απαιτούνται κατάλληλα μέτρα ασφαλείας· ο μηχανισμός redaction του ScamAI συμβάλλει άμεσα σε αυτήν την αρχή.
- *Λογοδοσία:* ο υπεύθυνος επεξεργασίας πρέπει να μπορεί να αποδείξει τη συμμόρφωση - εξ ου και η σημασία της τεκμηρίωσης (DPIA, αρχεία δραστηριοτήτων).

Δικαιώματα υποκειμένων (Άρθρα 15–22)

Ακόμη και οι απατεώνες, ως φυσικά πρόσωπα, διατηρούν δικαιώματα πρόσβασης, διόρθωσης και διαγραφής - γεγονός που περιπλέκει τη νόμιμη διατήρηση συνομιλιών και δημιουργεί ένταση με τον στόχο συλλογής threat intelligence.

DPIA (Άρθρο 35)

Η συστηματική, μεγάλης κλίμακας και καινοφανής επεξεργασία θα απαιτούσε *Εκτίμηση Αντικτύπου σχετικά με την Προστασία Δεδομένων* πριν την έναρξη.

Διασυννοριακές μεταφορές (Κεφάλαιο V)

Η χρήση εξωτερικών LLM APIs (συχνά εκτός EOX) εγείρει ζήτημα νόμιμης διαβίβασης (τυποποιημένες συμβατικές ρήτρες κ.λπ.). Ο offline mock provider αίρει πλήρως αυτόν τον κίνδυνο στο εκπαιδευτικό πλαίσιο.

Στο ScamAI οι κίνδυνοι ελαχιστοποιούνται εκ σχεδιασμού: τα σύνολα εκπαίδευσης είναι δημόσια/ερευνητικά corpora, δεν συλλέγονται νέα προσωπικά δεδομένα, ο guardrail αποκρύπτει

ενεργά τυχόν πραγματικά ΡΠ πριν από κάθε έξοδο, και όλες οι συνομιλίες είναι προσομοιωμένες (καμία διατήρηση δεδομένων πραγματικών υποκειμένων).

8.3. Πράξη για την Τεχνητή Νοημοσύνη (AI Act) - Άρθρο 50

Η Πράξη για την Τεχνητή Νοημοσύνη υιοθετεί μια προσέγγιση βασισμένη στον κίνδυνο (risk-based), κατατάσσοντας τα συστήματα σε τέσσερις βαθμίδες: (i) *απαγορευμένες* πρακτικές (π.χ. κοινωνική βαθμολόγηση, χειραγώγηση με υποσυνείδητες τεχνικές)· (ii) *υψηλού κινδύνου* συστήματα (π.χ. σε κρίσιμες υποδομές, απασχόληση, δικαιοσύνη), με αυστηρές υποχρεώσεις διαχείρισης κινδύνου, διακυβέρνησης δεδομένων και ανθρώπινης εποπτείας· (iii) *περιορισμένου κινδύνου* συστήματα, που υπόκεινται κυρίως σε υποχρεώσεις διαφάνειας· και (iv) *ελάχιστου κινδύνου* συστήματα, χωρίς ειδικές υποχρεώσεις. Ένα conversational σύστημα scambaiting εντάσσεται τυπικά στη βαθμίδα *περιορισμένου κινδύνου*, όπου κυριαρχεί η υποχρέωση διαφάνειας του Άρθρου 50. Επιπλέον, τα μοντέλα γενικού σκοπού (GPAI) που τροφοδοτούν τον responder υπόκεινται σε δικές τους υποχρεώσεις τεκμηρίωσης.

Ιδιαίτερα κρίσιμο για ένα σύστημα scambaiting είναι το Άρθρο 50(1) του Καν. (ΕΕ) 2024/1689 [33]: οι πάροχοι συστημάτων ΤΝ που αλληλεπιδρούν άμεσα με φυσικά πρόσωπα οφείλουν να διασφαλίζουν ότι το πρόσωπο ενημερώνεται πως συνομιλεί με ΤΝ - εκτός αν αυτό είναι προφανές σε έναν εύλογα ενημερωμένο παρατηρητή. Εδώ αναδύεται μια θεμελιώδης ένταση: το scambaiting βασίζεται *εξ ορισμού* στον δόλο· ο απατεώνας δεν πρέπει να αντιληφθεί ότι συνομιλεί με bot, αλλιώς χάνεται όλη η αξία της εμπλοκής.

Ο κανονισμός προβλέπει, ωστόσο, ρητή εξαίρεση για συστήματα εξουσιοδοτημένα από τον νόμο για την ανίχνευση, πρόληψη, διερεύνηση ή δίωξη ποινικών αδικημάτων, υπό κατάλληλες εγγυήσεις για τα δικαιώματα τρίτων. Το νομικό συμπέρασμα είναι σαφές: ένα πραγματικό σύστημα scambaiting θα ήταν υπερασπίσιμο μόνο εντός θεσμοθετημένου πλαισίου δίωξης του εγκλήματος (π.χ. υπό διωκτική αρχή) - όχι ως ιδιωτική πρωτοβουλία. Οι υποχρεώσεις του Άρθρου 50 καθίστανται εφαρμοστέες από τις 2 Αυγούστου 2026. Το ScamAI,

ως προσομοιωμένο εκπαιδευτικό εργαλείο χωρίς αλληλεπίδραση με πραγματικά πρόσωπα, δεν εμπίπτει στην πράξη στην υποχρέωση αυτή.

8.4.NIS2 και threat intelligence

Η Οδηγία (ΕΕ) 2022/2555 (NIS2) [34] διευρύνει σημαντικά το πεδίο της προηγούμενης οδηγίας NIS, διακρίνοντας μεταξύ «ουσιωδών» (essential) και «σημαντικών» (important) φορέων σε τομείς όπως η ενέργεια, οι μεταφορές, οι τράπεζες, η υγεία και οι ψηφιακές υποδομές. Επιβάλλει υποχρεώσεις διαχείρισης κινδύνων κυβερνοασφάλειας (μέτρα τεχνικά και οργανωτικά, ασφάλεια εφοδιαστικής αλυσίδας, διαχείριση ευπαθειών), έγκαιρη αναφορά περιστατικών (με πρώιμη ειδοποίηση εντός 24 ωρών) και ευθύνη της διοίκησης. Ένα σύστημα scambaiting που παράγει threat intelligence -τραπεζικοί λογαριασμοί «μουλαριών» (mule accounts), τακτικές επιτιθέμενων, δείκτες συμβιβασμού (IoCs)- θα μπορούσε να τροφοδοτεί τέτοιες διαδικασίες και να ενισχύει τη συλλογική άμυνα. Ωστόσο, η αξιοποίηση αυτή προϋποθέτει ότι η συλλογή και ανταλλαγή στοιχείων γίνεται εντός νόμιμων διαύλων (εθνικές ομάδες CSIRT, διωκτικές αρχές, θεσμοθετημένα δίκτυα ανταλλαγής πληροφοριών) και όχι μέσω ιδιωτικής «δικαιοσύνης» - διάκριση που επανέρχεται στην ηθική ανάλυση (κεφάλαιο 9).

8.5. Ποινικό δίκαιο και κυβερνοέγκλημα

Η Οδηγία 2013/40/ΕΕ [35] για τις επιθέσεις κατά συστημάτων πληροφοριών (που αντικατέστησε την Απόφαση-Πλαίσιο 2005/222/ΔΕΥ και βασίζεται στη Σύμβαση της Βουδαπέστης του 2001 [37]) ποινικοποιεί την παράνομη πρόσβαση σε σύστημα, την παρεμβολή σε συστήματα/δεδομένα και την παράνομη υποκλοπή. Αυτό οριοθετεί με ακρίβεια το scambaiting: η απλή χρονοτριβή μέσω συνομιλίας είναι νόμιμη, αλλά κάθε ενέργεια «αντεπίθεσης» (*hack-back*) -μη εξουσιοδοτημένη πρόσβαση στα συστήματα του απατεώνα, εγκατάσταση κακόβουλου λογισμικού, ή δημόσια έκθεση προσωπικών δεδομένων- συνιστά

αδίκημα, ανεξαρτήτως των «καλών προθέσεων» του δράστη. Παράλληλα, η ίδια η απάτη τιμωρείται από το ελληνικό δίκαιο (απάτη, άρθρο 386 ΠΚ). Το ScamAI, εκ σχεδιασμού, δεν προβαίνει σε καμία τέτοια ενέργεια: παράγει μόνο κειμενικές απαντήσεις σε προσομοιωμένα emails.

8.6. Ελληνικό πλαίσιο

Η προστασία δεδομένων στην Ελλάδα θεμελιώνεται συνταγματικά στο Άρθρο 9Α του Συντάγματος (αναθεώρηση 2001) [40], που κατοχυρώνει ρητό δικαίωμα προστασίας προσωπικών δεδομένων. Εξειδικεύεται με τον Ν. 4624/2019 (ΦΕΚ Α'137/29.08.2019) [38], ο οποίος εφαρμόζει τον GDPR αξιοποιώντας τις «ρήτρες ευελιξίας» και μεταφέρει την Οδηγία (ΕΕ) 2016/680 (LED) [36]. Αρμόδια εποπτική αρχή είναι η Αρχή Προστασίας Δεδομένων Προσωπικού Χαρακτήρα (ΑΠΔΠΧ), με εξουσίες ελέγχου, επιβολής διοικητικών προστίμων και παραπομπής υποθέσεων για ποινική δίωξη. Το απόρρητο των ηλεκτρονικών επικοινωνιών και οι αυτόκλητες επικοινωνίες διέπονται από τον Ν. 3471/2006 [39] (ePrivacy). Το πεδίο εφαρμογής του Ν. 4624/2019 καλύπτει φορείς εγκατεστημένους στην Ελλάδα, επεξεργασία εντός Ελλάδας, ή επεξεργασία δεδομένων Ελλήνων πολιτών.

8.7. Ενδεικτική άσκηση DPIA

Για μια πραγματική ανάπτυξη, μια στοιχειώδης Εκτίμηση Αντικτύπου θα κατέγραφε: (i) σκοπό - πρόληψη απάτης/συλλογή threat intelligence· (ii) κατηγορίες δεδομένων - περιεχόμενο email, ταυτοποιητικά, οικονομικά στοιχεία απατεώνων· (iii) κινδύνους - παράνομη διατήρηση, διαρροή PII, εσφαλμένη στόχευση αθώων, κλιμάκωση· (iv) μέτρα - ελαχιστοποίηση, redaction, ανθρώπινη εποπτεία, νόμιμη βάση και θεσμικό πλαίσιο. Το γεγονός ότι το ScamAI υλοποιεί ήδη redaction και ανθρώπινη έγκριση δείχνει τη λογική «privacy by design».

8.8. Συμμόρφωση εκ σχεδιασμού (compliance by design)

Απαίτηση	Πώς την ικανοποιεί το ScamAI
Ελαχιστοποίηση δεδομένων (GDPR Art. 5)	Μόνο δημόσια/ερευνητικά corpora· καμία νέα συλλογή
Προστασία PII	Ενεργή απόκρυψη IBAN/κάρτας/wallet/email/τηλεφώνου
Διαφάνεια TN (AI Act Art. 50)	Δεν αλληλεπιδρά με πραγματικά πρόσωπα (προσομοίωση)
Μη παράνομη πρόσβαση (Οδ. 2013/40)	Καμία ενέργεια πέραν παραγωγής κειμένου
Αποφυγή κλιμάκωσης	Αυτόματο μπλοκάρισμα ραντεβού/διευθύνσεων/απειλών
Ανθρώπινη εποπτεία	Καμία αυτόματη αποστολή· μόνο προσχέδια απαντήσεων
Αποφυγή διασυννοριακών μεταφορών	Offline mock provider

8.9. Ευθύνη και δικαιοδοσία

Πέρα από τη συμμόρφωση, τίθεται ζήτημα *αστικής και ποινικής ευθύνης*. Αν μια αυτόματη απόκριση προκαλούσε βλάβη σε τρίτο -για παράδειγμα, λόγω εσφαλμένης στόχευσης ενός νόμιμου αποστολέα που χαρακτηρίστηκε εσφαλμένα ως απατεώνας (false positive)- τίθεται το ερώτημα ποιος ευθύνεται: ο πάροχος του υποκείμενου μοντέλου, ο φορέας που ανέπτυξε το σύστημα, ή ο τελικός χρήστης που το ενεργοποίησε. Το ζήτημα περιπλέκεται από την «αδιαφάνεια» των γλωσσικών μοντέλων και την απουσία πλήρους προβλεψιμότητας της εξόδου τους.

Επιπλέον, το διασυννοριακό στοιχείο είναι εγγενές: ο απατεώνας βρίσκεται συχνά σε διαφορετική δικαιοδοσία από το θύμα και από τον φορέα του συστήματος. Αυτό εγείρει

ζητήματα εφαρμοστέου δικαίου (ποιου κράτους οι κανόνες ισχύουν), διεθνούς δικαστικής συνεργασίας και πρακτικής επιβολής - ακόμη και αν μια ενέργεια είναι νόμιμη σε μια χώρα, μπορεί να μην είναι σε άλλη. Η Σύμβαση της Βουδαπέστης [37] παρέχει ένα πλαίσιο διεθνούς συνεργασίας, αλλά η εφαρμογή παραμένει άنيση. Τα ερωτήματα αυτά ενισχύουν το κεντρικό συμπέρασμα της εργασίας: μια βιώσιμη ανάπτυξη ενός συστήματος scambaiting δεν είναι ζήτημα μόνο τεχνικής, αλλά προϋποθέτει σαφές θεσμικό, νομικό και διεθνές πλαίσιο.

9. Ηθική Ανάλυση

9.1. Το παράδοξο του δόλου

Το scambaiting αντιμετωπίζει τον δόλο *με δόλο*. Ακόμη κι όταν ο τελικός σκοπός (η προστασία θυμάτων) είναι αξιόπαινος, το μέσο (συστηματική εξαπάτηση) εγείρει ζήτημα ηθικής συνέπειας: νομιμοποιείται μια ΤΝ να προσποιείται συστηματικά έναν άνθρωπο για να παραπλανήσει; Το παράδοξο εντείνεται στην αυτοματοποιημένη εκδοχή για τρεις λόγους. Πρώτον, η *κλίμακα*: ένα σύστημα μπορεί να διεξάγει χιλιάδες παραπλανητικές συνομιλίες ταυτόχρονα, κάτι ανέφικτο για μεμονωμένους εθελοντές. Δεύτερον, η *απόσταση ευθύνης*: όταν η εξαπάτηση παράγεται από αλγόριθμο, θολώνει το ποιος φέρει την ηθική ευθύνη. Τρίτον, η *αυτονομία*: ένα μοντέλο μπορεί να παραγάγει περιεχόμενο που ο σχεδιαστής δεν προέβλεψε ούτε ενέκρινε. Οι τρεις αυτές διαστάσεις καθιστούν την ανθρώπινη εποπτεία (human-in-the-loop) όχι απλώς επιθυμητή αλλά ηθικά αναγκαία.

9.2. Ωφελιμιστική, δεοντολογική και αρετολογική οπτική

Από ωφελιμιστική σκοπιά, το scam-baiting δικαιολογείται αν το συνολικό όφελος (αποτροπή απάτης, εκτροπή χρόνου/πόρων του απατεώνα, threat intelligence που προστατεύει μελλοντικά θύματα) υπερβαίνει τη συνολική βλάβη. Ο υπολογισμός αυτός, ωστόσο, είναι εμπειρικά αβέβαιος: δεν είναι σαφές αν η εκτροπή ενός απατεώνα μειώνει τον συνολικό αριθμό θυμάτων ή απλώς μετατοπίζει τη στόχευση. Από δεοντολογική σκοπιά (κατά Kant), η εσκεμμένη εξαπάτηση παραμένει καθαυτή προβληματική, ανεξαρτήτως αποτελέσματος, καθώς μεταχειρίζεται το πρόσωπο ως μέσο· ακόμη κι αν ο απατεώνας «το αξίζει», η καθολίκευση του κανόνα «επιτρέπεται να εξαπατώ όποιον θεωρώ ένοχο» είναι επικίνδυνη. Από αρετολογική σκοπιά (κατά Αριστοτέλη), το ερώτημα μετατοπίζεται στον χαρακτήρα: καλλιεργεί η πρακτική την αρετή της προστασίας ή μήπως την κακία της εκδίκησης και της απόλαυσης εις βάρος του άλλου; Το ScamAI, περιορίζοντας ρητά τη συμπεριφορά (καμία σκληρότητα, καμία έκθεση, μόνο χρονοτριβή), προσπαθεί να παραμείνει στην πρώτη πλευρά κάθε μιας από αυτές τις τρεις οπτικές.

9.3. Ευάλωτοι πληθυσμοί

Κρίσιμη ηθική διάσταση είναι ότι μέρος των «απατεώνων» ενδέχεται να είναι οι ίδιοι θύματα. Πρόσφατες έρευνες και δημοσιογραφικές αποκαλύψεις τεκμηριώνουν την ύπαρξη «scam farms» - οργανωμένων εγκαταστάσεων, ιδίως στη Νοτιοανατολική Ασία, όπου άτομα υπό καθεστώς εμπορίας ανθρώπων και εξαναγκασμού αναγκάζονται να διεξάγουν απάτες υπό την απειλή βίας. Ένα αυτοματοποιημένο σύστημα που «τιμωρεί» αδιακρίτως όποιον στέλνει ένα απατηλό μήνυμα ενδέχεται να πλήττει τους πιο ευάλωτους κρίκους της αλυσίδας -τα εξαναγκασμένα άτομα- αντί των πραγματικών οργανωτών του εγκλήματος. Αυτό επιβάλλει έναν επιπλέον ηθικό περιορισμό: η εμπλοκή πρέπει να στοχεύει στην *εκτροπή και τη συλλογή πληροφοριών*, ποτέ στην τιμωρία ή τον εξευτελισμό του προσώπου στην άλλη άκρη, του οποίου οι πραγματικές συνθήκες είναι άγνωστες.

9.4. Βλάβη σε τρίτους και διπλή χρήση (dual-use)

Το scam-baiting μπορεί ακούσια να βλάψει αθώους (έκθεση στοιχείων τρίτου, λανθασμένη στόχευση νόμιμου αποστολέα λόγω false positive). Επιπλέον, η ίδια τεχνολογία «πειστικής αυτοματοποιημένης συνομιλίας» έχει προφανή διπλή χρήση: μπορεί να αξιοποιηθεί και για απάτη. Η ευθύνη του σχεδιαστή περιλαμβάνει την πρόβλεψη τέτοιων καταχρήσεων.

9.5. Αντιστοίχιση με αρχές Υπεύθυνης ΤΝ

Οι σχεδιαστικές επιλογές του ScamAI αντιστοιχούν σε καθιερωμένες αρχές Υπεύθυνης ΤΝ [26]:

- Έλεγχοι εξόδου/αποκλεισμός επικίνδυνων ενεργειών: ο safety_check ελέγχει κάθε έξοδο.
- Διαχωρισμός δεδομένων από εντολές: το κακόβουλο κείμενο απομονώνεται ως δεδομένο (άμυνα σε prompt injection).
- Ανθρώπινη εποπτεία (human-in-the-loop): καμία αυτόματη αποστολή· το prototype παράγει μόνο *προσχέδια* απαντήσεων προς ανθρώπινη έγκριση.
- Διαφάνεια & αναπαραγωγιμότητα: ερμηνεύσιμα χαρακτηριστικά, ντετερμινιστικό mock mode, ανοικτή τεκμηρίωση.

10. Μελλοντική εργασία

- Πλουσιότερα χαρακτηριστικά: ενσωμάτωση TF-IDF ή embeddings αναμένεται να βελτιώσει σημαντικά precision/F1.
- Διαχείριση ανισορροπίας: τεχνικές resampling (SMOTE [6]) ή βελτιστοποίηση κατωφλίου για καλύτερη ισορροπία precision/recall.

- Επιβλεπόμενη ταυτοποίηση τύπου: αντικατάσταση του keyword scoring με μικρό εκπαιδευμένο ταξινομητή τύπου απάτης.
- Ισχυρότερα guardrails: συνδυασμός των regex ελέγχων με ειδικευμένα safety classifiers και δοκιμές αντοχής σε prompt injection.
- Ποσοτική αξιολόγηση responder: ελεγχόμενα, ηθικά εγκεκριμένα πειράματα με προσομοιωμένους αντιπάλους.
- Νομική βιωσιμότητα: μελέτη ενσωμάτωσης εντός θεσμικού πλαισίου δίωξης (AI Act Art. 50 exemption) με πλήρη DPIA.

11. Συμπεράσματα

Η παρούσα εργασία σχεδίασε, υλοποίησε και αξιολόγησε το ScamAI, ένα ολοκληρωμένο, εκπαιδευτικό σύστημα δύο σταδίων που καλύπτει όλη την αλυσίδα anti-scam: από την ανίχνευση με ερμηνεύσιμη Μηχανική Μάθηση έως την αυτοματοποιημένη, *ασφαλή* απόκριση με Παραγωγική ΤΝ.

11.1. Απαντήσεις στα ερευνητικά ερωτήματα

Η εργασία απαντά στα τέσσερα ερωτήματα που τέθηκαν στην Ενότητα 1.4:

- (E1) Ανίχνευση με ελαφρύ, ερμηνεύσιμο μοντέλο. Ναι: ακόμη και ένα σύνολο 8 διαφανών χαρακτηριστικών επιτυγχάνει χρήσιμη ικανότητα διαχωρισμού (Random Forest, ROC-AUC 0,815, recall 0,65) σε ρεαλιστικά, μη ισορροπημένα δεδομένα (7,7% απάτη), εντοπίζοντας τα δύο τρίτα των απατών. Η πλήρης αποτυχία του Naive Bayes επιβεβαιώνει ότι η διαχείριση της ανισορροπίας (μέσω class_weight) είναι καθοριστική.

- (E2) Πειστική αλλά ασφαλής απόκριση. Επιτυγχάνεται με τον συνδυασμό διακριτών περσόνων ανά τύπο απάτης, multi-turn συνοχής και ρητού ελέγχου ασφαλείας εξόδου που αποκρύπτει PII και μπλοκάρει επικίνδυνο περιεχόμενο πριν από κάθε έξοδο.
- (E3) Ασφάλεια σε εχθρικό περιβάλλον. Ο κύριος κίνδυνος (prompt injection) αντιμετωπίζεται με τον διαχωρισμό δεδομένων/εντολών, τη ρητή οδηγία μη εκτέλεσης και τον έλεγχο εξόδου ως τελευταία γραμμή άμυνας — μια στρατηγική «άμυνας σε βάθος».
- (E4) Νομικό και ηθικό πλαίσιο. Η ανάλυση κατέδειξε ότι μια πραγματική ανάπτυξη θα ήταν υπερασπίσιμη μόνο εντός θεσμοθετημένου πλαισίου δίωξης του εγκλήματος, με νόμιμη βάση κατά GDPR, συμμόρφωση προς το Άρθρο 50 του AI Act και σεβασμό του ποινικού δικαίου του κυβερνοχώρου.

11.2. Συνεισφορά

Η συνεισφορά είναι πρωτίστως διδακτική: ένα πλήρες, αναπαραγώγιμο και offline-δυνατό παράδειγμα ενσωμάτωσης Μηχανικής Μάθησης, Παραγωγικής TN και αρχών Υπεύθυνης TN (έλεγχοι εξόδου, διαχωρισμός δεδομένων/εντολών, human-in-the-loop), συνοδευόμενο από ενδεδειγμένη νομική και ηθική ανάλυση που σπάνια συνοδεύει τεχνικές εργασίες αυτού του τύπου.

11.3. Περιορισμοί

Τα ευρήματα πρέπει να ερμηνεύονται υπό τους περιορισμούς της εργασίας: το ρηχό σύνολο χαρακτηριστικών (χωρίς TF-IDF/embeddings) θέτει άνω όριο στην απόδοση· η ανίχνευση τύπου απάτης βασίζεται σε λέξεις-κλειδιά και είναι ευάλωτη σε αντιπαλική διατύπωση· οι έλεγχοι ασφαλείας είναι κανόνες (regex) και δεν καλύπτουν κάθε πιθανή διαρροή· και η αξιολόγηση του responder είναι κατ' ανάγκη ποιοτική, καθώς η ποσοτική θα απαιτούσε αλληλεπίδραση με

πραγματικούς απατεώνες - κάτι που η εργασία σκόπιμα αποφεύγει για νομικούς και ηθικούς λόγους.

11.4. Καταληκτικές παρατηρήσεις

Το συνολικό συμπέρασμα είναι ενιαίο: η ενεργητική άμυνα απέναντι στην απάτη είναι τεχνικά εφικτή, αλλά *αξεδιάλυτα* συνδεδεμένη με το GDPR, την Πράξη για την Τεχνητή Νοημοσύνη, το ποινικό δίκαιο του κυβερνοχώρου και θεμελιώδεις ηθικές δεσμεύσεις. Μια βιώσιμη υλοποίηση, επομένως, δεν είναι ζήτημα μόνο μηχανικής: προϋποθέτει θεσμικό πλαίσιο, νόμιμη βάση και διαρκή ανθρώπινη εποπτεία - αρχές που το ScamAI υιοθετεί, σε προσομοιωμένη μορφή, ήδη από τον σχεδιασμό του. Καθώς οι απατεώνες αξιοποιούν ολοένα και περισσότερο την Παραγωγική ΤΝ, η ανάγκη για εξίσου έξυπνες, αλλά υπεύθυνες, αμυντικές προσεγγίσεις θα γίνεται μόνο πιο επιτακτική.

12.Βιβλιογραφία

12.1. Επιστημονική βιβλιογραφία

[1] M. Sahami, S. Dumais, D. Heckerman, E. Horvitz, «A Bayesian Approach to Filtering Junk E-Mail», *AAAI Workshop on Learning for Text Categorization*, 1998.

[2] I. Androutsopoulos, J. Koutsias, K. V. Chandrinos, G. Paliouras, C. D. Spyropoulos, «An Evaluation of Naive Bayesian Anti-Spam Filtering», *ECML Workshop on Machine Learning in the New Information Age*, 2000.

- [3] E. G. Dada, J. S. Bassi, H. Chiroma, S. M. Abdulhamid, A. O. Adetunmbi, O. E. Ajibuwa, «Machine learning for email spam filtering: review, approaches and open research problems», *Heliyon*, 5(6), e01802, 2019.
- [4] A. Karim, S. Azam, B. Shanmugam, K. Kannoorpatti, M. Alazab, «A Comprehensive Survey for Intelligent Spam Email Detection», *IEEE Access*, 7, 168261–168295, 2019.
- [5] L. Breiman, «Random Forests», *Machine Learning*, 45(1), 5–32, 2001.
- [6] N. V. Chawla, K. W. Bowyer, L. O. Hall, W. P. Kegelmeyer, «SMOTE: Synthetic Minority Over-sampling Technique», *Journal of Artificial Intelligence Research*, 16, 321–357, 2002.
- [7] M. A. Uddin, M. Mahiuddin, I. H. Sarker, «An Explainable Transformer-based Model for Phishing Email Detection: A Large Language Model Approach», arXiv:2402.13871, 2024.
- [8] S. Jamal, H. Wimmer, I. H. Sarker, «An Improved Transformer-based Model for Detecting Phishing, Spam, and Ham: A Large Language Model Approach», arXiv:2311.04913, 2023.
- [9] R. B. Cialdini, *Influence: The Psychology of Persuasion*, Revised Edition, Harper Business, 2007.
- [10] D. Gragg, «A Multi-Level Defense Against Social Engineering», *SANS Institute Reading Room*, 2003.
- [11] F. Stajano, P. Wilson, «Understanding scam victims: Seven principles for systems security», *Communications of the ACM*, 54(3), 70–75, 2011.
- [12] A. Ferreira, L. Coventry, G. Lenzini, «Principles of Persuasion in Social Engineering and Their Use in Phishing», *Human Aspects of Information Security, Privacy and Trust (HCII)*, LNCS 9190, 36–47, 2015.
- [13] C. Herley, «Why do Nigerian Scammers Say They are from Nigeria?», *Workshop on the Economics of Information Security (WEIS)*, 2012.
- [14] M. Edwards, C. Peersman, A. Rashid, «Scamming the scammers: towards automatic detection of persuasion in advance fee frauds», *Proc. 26th International Conference on World Wide Web Companion (WWW '17 Companion)*, 1291–1299, 2017.

- [15] A. Zingerle, L. Kronman, «Humiliating Entertainment or Social Activism? Analyzing Scambaiting Strategies Against Online Advance Fee Fraud», *International Conference on Cyberworlds (IEEE)*, 352–355, 2013.
- [16] L. Tuovinen, J. Rönning, «Baits and Beatings: Vigilante Justice in Virtual Communities», *Proc. Conference on Computer Ethics: Philosophical Enquiry (CEPE)*, 397–405, 2007.
- [17] T. Sorell, «Scambaiting on the Spectrum of Digilantism», *Criminal Justice Ethics*, 38(3), 153–175, 2019.
- [18] A. S. Ross, L. Logi, «“Hello, this is Martha”: Interaction dynamics of live scambaiting on Twitch», *Convergence*, 27(6), 1789–1810, 2021.
- [19] P. Bajaj, M. Edwards, «Automatic Scam-Baiting Using ChatGPT», arXiv:2309.01586, 2023.
- [20] Netsafe, «Re:Scam» — automated email scambaiting bot, 2017.
- [21] B. Acharya, D. Sautter, M. Saad, T. Holz, «ScamChatBot: An End-to-End Analysis of Fake Account Recovery on Social Media via Chatbots», arXiv:2412.15072, 2024.
- [22] «The Imitation Game: Using Large Language Models as Chatbots to Combat Chat-Based Cybercrimes (LURE)», arXiv:2512.21371, 2025.
- [23] N. Vogler et al., «Victim as a Service: Designing a System for Engaging with Interactive Scammers (CHATTERBOX)», arXiv:2510.23927, 2025.
- [24] H. Siadati, H. Jafarian, S. Jafarikhah, «“Send to which account?” Evaluation of an LLM-based Scambaiting System», arXiv:2509.08493, 2025.
- [25] I. Hossain, S. Puppala, M. J. Alam, S. Talukder, «AI-in-the-Loop: Privacy Preserving Real-Time Scam Detection and Conversational Scambaiting by Leveraging LLMs and Federated Learning», arXiv:2509.05362, 2025.
- [26] A. Askeel, Y. Bai, A. Chen, et al., «A General Language Assistant as a Laboratory for Alignment», arXiv:2112.00861, 2021.

- [27] F. Perez, I. Ribeiro, «Ignore Previous Prompt: Attack Techniques For Language Models», *NeurIPS ML Safety Workshop*, 2022.
- [28] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, M. Fritz, «Not what you’ve signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection», *Proc. 16th ACM Workshop on Artificial Intelligence and Security (AISec)*, 79–90, 2023.
- [29] «Prompt Injection Attacks on Large Language Models: A Survey of Attack Methods, Root Causes, and Defense Strategies», *Computers, Materials & Continua*, 2026.
- [30] F. W. Liu, C. Hu, «Exploring Vulnerabilities and Protections in Large Language Models: A Survey», arXiv:2406.00240, 2024.
- [31] OWASP Foundation, «OWASP Top 10 for Large Language Model Applications», 2025.

12.2. Νομικά μέσα

- [32] Κανονισμός (ΕΕ) 2016/679 (Γενικός Κανονισμός για την Προστασία Δεδομένων — GDPR).
- [33] Κανονισμός (ΕΕ) 2024/1689 (Πράξη για την Τεχνητή Νοημοσύνη — AI Act), ιδίως Άρθρο 50.
- [34] Οδηγία (ΕΕ) 2022/2555 (NIS2).
- [35] Οδηγία 2013/40/ΕΕ για τις επιθέσεις κατά συστημάτων πληροφοριών (ΕΕ L 218, 14.8.2013).
- [36] Οδηγία (ΕΕ) 2016/680 (Law Enforcement Directive — LED).
- [37] Σύμβαση του Συμβουλίου της Ευρώπης για το Κυβερνοέγκλημα (Σύμβαση της Βουδαπέστης), 2001.

[38] Ν. 4624/2019 «Αρχή Προστασίας Δεδομένων Προσωπικού Χαρακτήρα...» (ΦΕΚ Α'137/29.08.2019).

[39] Ν. 3471/2006 για την προστασία δεδομένων στις ηλεκτρονικές επικοινωνίες (ePrivacy).

[40] Άρθρο 9Α του Συντάγματος της Ελλάδας (αναθεώρηση 2001).

12.3. Πρόσθετες αναφορές (ενεργητική άμυνα & απάτη)

[41] W. Chen, F. Wang, M. Edwards, «Active countermeasures for email fraud», *Proc. 8th IEEE European Symposium on Security and Privacy (EuroS&P)*, 2023.

[42] M. Canham, J. Tuthill, «Planting a poison SEAD: Using social engineering active defense (SEAD) to counter cybercriminals», *Proc. International Conference on Human-Computer Interaction (HCII)*, Springer, 48–57, 2022.

[43] R. Zbinden, O. Beaudet-Labrecque, F. Grandjean, C. Gobeil, L. Brunoni, D. Décary-Héту, C. Cretu-Adatte, «Scambaiting as a preventive tool in the fight against cyberfrauds: the case of romance scams», *The Journal on Cybercrime & Digital Investigations*, 2023.

[44] I. Chadalavada, T. Huang, J. Staddon, «Distinguishing Scams and Fraud with Ensemble Learning», arXiv:2412.08680, 2024.

[45] X. W. Tan, K. See, S. Kok, «ScamGPT-J: Inside the Scammer's Mind, A Generative AI-Based Approach Toward Combating Messaging Scams», arXiv:2412.13528, 2024.

[46] B. Acharya, T. Holz, «An explorative study of pig butchering scams», arXiv:2412.15423, 2024.

[47] Federal Bureau of Investigation (FBI), Internet Crime Complaint Center (IC3), «2024 Internet Crime Report», 2025.

13. Παραρτήματα

13.1. Παράρτημα Α - Πλήρες transcript multi-turn (mock provider)

Τύπος απάτης: nigerian_prince· 3 γύροι· όλοι με καθαρό έλεγχο ασφαλείας. Πλήρες αρχείο: transcript_nigerian.md.

13.2. Παράρτημα Β - Ορισμοί χαρακτηριστικών

Βλ. §4.4 για τον πλήρη πίνακα των 8 χαρακτηριστικών και τη λογική τους.

13.3. Παράρτημα Γ - Γλωσσάρι

- **Scambaiting:** η εσκεμμένη εμπλοκή με απατεώνα ώστε να σπαταληθεί ο χρόνος/πόροι του.
- **Advance-fee fraud («419»):** απάτη προκαταβολικής αμοιβής.
- **Prompt injection:** επίθεση όπου κακόβουλες εντολές ενσωματώνονται σε δεδομένα εισόδου LLM.
- **PII:** δεδομένα προσωπικού χαρακτήρα (Personally Identifiable Information).
- **DPIA:** Εκτίμηση Αντικτύπου σχετικά με την Προστασία Δεδομένων.
- **ROC-AUC:** εμβαδόν κάτω από την καμπύλη ROC· μέτρο ικανότητας διαχωρισμού.

13.4. Παράρτημα Δ - Κατανομή ρόλων ομάδας

Ρόλος	Αρμοδιότητα
Άτομο 1	Dataset & Preprocessing
Άτομο 2	ML Classifier
Άτομο 3	Generative AI Responder
Άτομο 4	Pipeline & Demo UI
Άτομο 5	Literature Review & Ethics
Άτομο 6	Report & Coordination

13.5. Παράρτημα Ε - Επιλεγμένα αποσπάσματα κώδικα

Παρατίθενται τρία αντιπροσωπευτικά αποσπάσματα του πραγματικού κώδικα, ώστε η αναφορά να τεκμηριώνει και την υλοποίηση.

13.6. Ε.1 Εξαγωγή χαρακτηριστικών (preprocessing/preprocess.py)

```
def extract_features(text: str) -> dict:
    cleaned = clean_text(text)
    tokens = word_tokenize(cleaned)
    tokens_no_stop = [t for t in tokens if t not in STOP_WORDS]

    word_count = len(tokens)
    unique_words = len(set(tokens_no_stop))
    avg_word_length = (
        sum(len(w) for w in tokens_no_stop) / len(tokens_no_stop)
        if tokens_no_stop else 0
```

)

```
scam_keyword_count = sum(1 for kw in SCAM_KEYWORDS if kw in cleaned)
```

```
# Capitalization signals (scammers SHOUTING)
```

```
original_words = text.split()
```

```
caps_ratio = (
```

```
    sum(1 for w in original_words if w.isupper() and len(w) > 2)
```

```
    / len(original_words) if original_words else 0
```

```
)
```

```
exclamation_count = text.count("!")
```

```
question_count = text.count("?")
```

```
# Money mentions — στο APXIKO text (πριν αφαιρεθούν $ και ψηφία)
```

```
money_mentions = len(re.findall(
```

```
    r"\$[\d,]+\d+\s*(?:million|billion|usd|dollars|gbp)",
```

```
    text, flags=re.IGNORECASE))
```

```
return {
```

```
    "word_count": word_count, "unique_words": unique_words,
```

```
    "avg_word_length": avg_word_length,
```

```
    "scam_keyword_count": scam_keyword_count, "caps_ratio": caps_ratio,
```

```
    "exclamation_count": exclamation_count,
```

```
    "question_count": question_count, "money_mentions": money_mentions,
```

```
}
```

Το σχόλιο στη γραμμή των money_mentions τεκμηριώνει τη διόρθωση του bug που περιγράφεται στην §4.4: ο υπολογισμός γίνεται στο αρχικό κείμενο, πριν ο καθαρισμός αφαιρέσει σύμβολα και ψηφία.

13.6.1. E.2 Μοτίβα εντοπισμού PII (responder/responder.py)

```
_PII_PATTERNS = {  
    "iban": re.compile(r"\b[A-Z]{2}\d{2}[A-Z0-9]{10,30}\b"),  
    "credit_card": re.compile(r"\b(?:\d[-]){13,16}\b"),  
    "ssn": re.compile(r"\b\d{3}-\d{2}-\d{4}\b"),  
    "btc_wallet": re.compile(r"\b(?:bc1|[13])[a-km-zA-HJ-NP-Z1-9]{25,39}\b"),  
    "eth_wallet": re.compile(r"\b0x[a-fA-F0-9]{40}\b"),  
    "email": re.compile(r"\b[\w.+-]+@[ \w-]+\.[\w.-]+\b"),  
    "phone": re.compile(r"(?! \w)(?:\+?\d[\d\s()-.]{8,}\d)(?! \w)"),  
}
```

Τα μοτίβα καλύπτουν τις κύριες κατηγορίες πραγματικών στοιχείων που δεν πρέπει ποτέ να διαρρεύσουν σε μια απόκριση: διεθνείς τραπεζικοί αριθμοί (IBAN), κάρτες, αριθμοί κοινωνικής ασφάλισης, πορτοφόλια κρυπτονομισμάτων, email και τηλέφωνα.

13.6.2. E.3 Έλεγχος ασφαλείας εξόδου (responder/responder.py)

```
def safety_check(reply: str) -> dict:  
    issues = []  
    sanitized = reply or ""  
  
    # 1) Απειλές/κακοποίηση → HARD FAIL: όλη η απάντηση απορρίπτεται.  
    if _ABUSE_PATTERNS.search(sanitized):  
        return {"safe": False, "issues": ["abusive_content"],  
            "sanitized_reply": _SAFE_FALLBACK}  
  
    # 2) Πραγματικό ραντεβού/διεύθυνση → escalation risk → redact + flag.  
    if _MEETUP_PATTERNS.search(sanitized):
```

```

issues.append("meetup_or_address")
sanitized = _MEETUP_PATTERNS.sub("[REDACTED — no real meetings]", sanitized)

# 3) PII / banking / wallets → redact + flag.
for name, pat in _PII_PATTERNS.items():
    if pat.search(sanitized):
        issues.append(f"pii_{name}")
        sanitized = pat.sub(f"[REDACTED_{name.upper()})", sanitized)

# 4) Κενή/εκφυλισμένη απάντηση → ασφαλές fallback.
if not sanitized.strip():
    issues.append("empty_reply")
    sanitized = _SAFE_FALLBACK

return {"safe": len(issues) == 0, "issues": issues,
        "sanitized_reply": sanitized}

```

Η δομή αποτυπώνει την ιεραρχία κινδύνου: οι απειλές οδηγούν σε *πλήρη απόρριψη* (hard fail), ενώ τα PII και τα ραντεβού *αποκρύπτονται* (redaction) ώστε η συνομιλία να συνεχιστεί ασφαλώς. Η επιστροφή ενός δομημένου dict (safe/issues/sanitized_reply) επιτρέπει στο pipeline και στο UI να εμφανίζουν την κατάσταση ασφαλείας.